

Комплексный аудит проекта Анти-Дроп

Подготовка к конкурсу ВТБ
Финтех без границ

Проект тематически соответствует конкурсу. Текущая реализация представляет собой работающий демонстратор; банковские действия и дополнительный эффект для клиента пока не подтверждены.

Прогноз по представленным материалам 28 из 100 баллов. Диапазон экспертной оценки 18-38. Оценка не является результатом жюри и не определяет вероятность победы.

Дата аудита 8 октября 2026

Репозиторий github.com/dmitfadye/anti-drop-mvp Версия 565c72017c1be04e0734998b435d9db508940de9

Содержание

1 Общие выводы и стратегия проекта	3
2 Оценка по критериям жюри	10
3 Продукт аудитория рынок и метрики	13
4 Технический аудит и реестр дефектов	20
5 Технологии и целевая архитектура	26
6 Безопасность и регулирование	31
7 Бизнес модель и финансовые расчёты	36
8 MVP дорожная карта и банковский пилот	41
9 Демонстрация презентация и защита	45
10 Доказательства источники и ограничения	49

Документ объединяет выводы и подробные материалы аудита в десять разделов. Общие выводы вынесены в начало; факты, ограничения и основания оценок раскрыты в профильных разделах. Числовые допущения финансовой модели не являются подтверждённым результатом пилота.

1 Общие выводы и стратегия проекта

Дата: **8 октября 2026**, Europe/Moscow. Репозиторий: dmitfadye/anti-drop-mvp, commit 565c72017c1be04e0734998b435d9db508940de9. Объект - текущие исходники, установленная локальная среда и синтетические сценарии. Это независимый экспертный прогноз, не официальная оценка ВТБ, не юридическое заключение и не подтверждение partnership.

Аудит охватывает технические, продуктовые, конкурсные, правовые и экономические риски. В рамках аудита продуктовый код, зависимости и lock-файлы не изменялись.

1.1 Ключевые выводы

Проект тематически хорошо подходит конкурсу, но готовность конкурсной заявки низкая. Сейчас это небольшой работающий демонстратор: правила анализируют переданные транзакции, UI показывает риск и алерт на одном из семи языков, квиз проверяется сервером. Реального мониторинга банковских событий, SMS-подтверждения, начисления наград, создания обращения и ограничения платежей нет. Эти границы существенно важнее выбора frontend framework.

Локально подтверждены: 14/14 штатных тестов, HTTP 200 для страницы/API health/docs/OpenAPI, CSV GREEN/0 и RED/85, переход UI в Edge к RED/85. Обнаружены воспроизводимые ошибки времени, SIM=0, смещения клиентов, обработки fallback; см. E02-E19. API пригоден для синтетической демонстрации с оговорками, не для подключения реальных клиентов.

Наиболее перспективный фокус: **понятное контекстное предупреждение и подтверждённая помощь поверх существующего банковского антифрода.** Конкурсные шансы вырастут от доказательства этого результата, а не от добавления ИИ или микросервисов.

1.2 Конкурсная готовность

Шкала взята из кейса пользователя, отдельная публикация организатора не сверялась. Прогноз по предъявленному репозиторию:

Сценарий	Спринт №1 /78	Онлайн-питч /22	Всего /100
Строгий	16	2	18
Обычный	24	4	28
Благосклонный	32	6	38

Диапазон **18-38/100**, уверенность общая низкая: команда, реальное выступление и исследования вне репозитория неизвестны. Баллы не предсказывают проходной порог или вероятность победы. После выполненных исследований, измерения эффекта и P0-исправлений условный потенциал **64-80/100** (51-62/78 +13-18/22). Планы и этот отчёт сами по себе таких баллов не дают.

Почти не подтверждены критерии доказательной базы, аудитории, метрик и команды. Для первого спринта требуется движение к MVP, а не готовая банковская production-система; это позволяет не реализовывать SIM/реальные награды и сосредоточиться на одном сценарии. До 01.11 нужно предъявить исследования, охват, метрики и честное демо. Финмодель/защита данных - фокус 16-29.11, пилот/масштабирование - 03-08.12, финал 11.12.

1.3 Продуктовая ценность

JTBD: «Когда мне предлагают принять и переслать чужие деньги и я не уверен в безопасности предложения, я хочу понять риск на понятном языке и быстро получить помощь банка, чтобы сохранить доступ к своим деньгам и не участвовать в опасной схеме».

Пользователь - клиент с языковым/контекстным барьером; нерезидентство не является синонимом такого барьера и не должно становиться риск-признаком. Плательщик/владелец эффекта - потенциально банк, но готовность покупать и owner пока неизвестны. Измеримый результат сейчас - риск-ответ и объяснение на синтетике; предотвращённые потери и изменение поведения **НЕ ПОДТВЕРЖДЕНЫ**.

Продуктовая гипотеза: одинаковый банковский сигнал риска + понятный согласованный текст увеличивают безопасное действие относительно текущего уведомления. Реального УТП пока нет: правила и шаблоны легко скопировать. Защищаемое преимущество может создать подтверждённая методика, данные о понимании, reviewed translations и короткий путь внедрения. [Product report \(раздел 3\)](#) содержит три формата описания, JTBD, 12 вопросов интервью, 6 гипотез, конкурентов и план эксперимента.

1.4 Техническое состояние

FastAPI/Pydantic/Uvicorn → stateless stdlib rules, quiz, SIM mock, templates → vanilla JS/Tailwind CDN. Второй app_stdlib.py повторяет UI/API, но использует то же ядро. БД, миграций, CI, Docker, auth, банковских интеграций, ML/RAG нет. Основной data flow и Mermaid представлены в [техническом отчёте \(раздел 4\)](#).

Область	Статус	Существенное доказательство
API/детектор/алерты на синтетике	VERIFIED	E02-E06/E26, main.py:71-86
Квиз	VERIFIED частично	Сервер проверяет ответы; не перечисляет деньги; main.py:90-92, src/quiz.py:62-79
SMS/смена/кулдаун	PARTIAL	Булевы флаги от клиента, нет хранения/enforcement; models.py:61-65, src/sim_security.py:17-49
Поддержка/заморозка	DOCUMENTED ONLY как банковское действие	static/index.html:151-154 только меняет DOM; E09
Неправильные дата/TZ, SIM сегодня	BROKEN	E10/E11: 500 и false
Граница клиента	BROKEN	E12: операции шести клиентов дают общий RED/70
Fallback parity/quiz privacy	BROKEN	E18/E19: correct в HTML, разрыв неизвестных GET
Реальная accuracy, SLA, mobile/a11y	NOT VERIFIED	Нет размеченной выборки, load test и полного UI QA

Ограниченная проверка зависимостей: pip check PASS; [OSV](#) не вернул известных advisory для 22 установленных пакетов 08.10.2026; сохранён ответ (машинное приложение). Это не гарантия безопасности и не проверка всех пакетов lock, CDN или ОС. Синтаксис 12 Python-файлов корректен. TestClient 5000 synthetic tx: median 37.9ms/max40.2ms на 10 последовательных вызовах; QPS и

production SLA не доказаны.

1.5 Рекомендуемые технологии

Оставить Python/FastAPI/Pydantic/Uvicorn и правила. Укрепить схемы/ошибки, безопасный DOM, локальный CSS, frozen dependency path. PostgreSQL добавлять для действительно сохраняемого case/audit; банковский gateway identity обязателен перед реальными данными. Один серверный путь вместо поддержки двух расходящихся реализаций.

React/Vue/TypeScript - возможны позже при росте UI или требовании банка; Next.js/Java/Go/Nest не дают сейчас доказанного выигрыша, цена переноса и повторной валидации выше пользы. Kafka/Redis/ClickHouse/Kubernetes не нужны для двух CSV; пользоваться банковской платформой по согласованному контракту, если масштаб потребует. RAG/vector DB/LLM не нужны. [Стек-отчёт \(раздел 5\)](#) сравнивает варианты, стоимость, лицензии и три архитектуры.

1.6 Безопасность

Самый опасный разрыв - выдача имитации за защитное банковское действие. Следующие риски: клиентские user_id/OTP/SIM, отсутствие auth/ACL, неполная валидация и HTML sinks, публичные JS-assets, отсутствие аудита и data governance. Локальное localhost демо на синтетике отличается от сервиса с реальными клиентами; критичность пилота не надо механически переносить на изолированную презентацию.

Для настоящих данных согласовать назначение, роли/основания обработки ПДн, банковскую тайну, минимизацию/retention, identity/RBAC, доверенный event source, локальные assets, TLS/egress, backup/restore и incident response. 152-ФЗ/115-ФЗ/161-ФЗ рассматриваются по назначению: проект сейчас не выполняет обязанности банка и не управляет переводами. Полная актуальная нормативная карта **НЕ ПОДТВЕРЖДЕНА**, её формирует банк. Юридические тексты «вам грозит суд/до 6 лет» не выводятся из score и требуют review. [Security report \(раздел 6\)](#) содержит threat model и разделение MVP/пилот/согласование/неприменимо.

1.7 Рынок и экономика

[Обзор Банка России за 2025](#) подтверждает общий контекст мошеннических операций, а [рекомендации по информированию](#) - актуальность профилактической коммуникации. Эти источники не подтверждают тезис «нерезиденты - главная мишень», размер нашего сегмента или эффективность продукта. Проверено 08.10.2026; публикационная дата страниц/номер рекомендаций надёжно не установлены.

У банка уже существуют [защитные инструкции](#), [«Защита близких»](#) и [обучение](#); [BI.ZONE](#) описывает зрелую antifraud-платформу (25.09.2023). Проверено 08.10.2026. Не известно, какие внутренние платформы ВТБ закрывают именно этот гар. Нельзя позиционироваться как замена без benchmark и процесса внедрения.

TAM/SAM/SOM численно не доказаны. Использовать eligible × reach × language × rollout, а не всех мигрантов или общий ущерб РФ. Иллюстративные N=10/50/150 тыс. - допущения, не статистика ВТБ. Модель [FINANCIAL_MODEL \(раздел 7\)](#) показывает annual margin −1.1345 млн/−470 тыс./+7.1475 млн ₽; первый год с K: −2.3345 млн/−2.27 млн/+4.1475 млн. База не окупается. Положительный оптимистичный сценарий требует подтверждения и не является обещанием 5-месячной окупаемости. Не учитывать сумму всех остановленных переводов как прибыль.

1.8 Работающий MVP

Готово: нормальный/атакующий фиксированный сценарий, правила, алерт, квиз, API docs. Не готово: независимая оценка качества, подтверждённый case, pre-transfer prevention, offline FastAPI UI, полноценный языковой путь и защищённые интеграции.

Текущая атака включает уже совершённый исходящий перевод. Пять входящих без иных сигналов дают 45/YELLOW, а алерт выдаётся только для RED. Поэтому нынешнее демо демонстрирует распознавание эпизода после вывода, не предотвращение первого вывода. Это критичный продуктовый предел, который нужно явно показать или изменить контракт будущего MVP.

Целевой MVP: один trusted episode → объяснение RU+один verified язык → официальный путь помощи → сохранённый sandbox case_id. Основной измеримый эксперимент - safe action uplift. Подробные acceptance/tests/failure cases/contracts находятся в [MVP_ROADMAP \(раздел 8\)](#). Настоящая SIM-смена и денежные награды не нужны для этой точки входа.

1.9 Путь к интеграции с ВТБ

Предполагаемый process owner: функция клиентского antifraud совместно с retail digital/support; конкретных людей, согласия и доступа нет. Начать с feasibility/usability на 200-500 добровольцах, затем read-only shadow на разрешённой истории/событиях, далее power-based UX A/B поверх одинаковой текущей защиты. Такой небольшой feasibility не доказывает сокращение редких финансовых потерь.

Зависимости: контракт риска/кейса, банк подтверждает subject и сигналы, legal/data/security approvals, labels и baseline, support capacity, feature flag/rollback. Успех: primary uplift с интервалом неопределённости + guardrails по ложным отказам/поддержке + подтверждённая экономика. Stop при privacy/unauthorised incidents немедленный; ухудшение UX/ошибок/нагрузки - остановка слоя и возврат стандартного warning. Масштабировать языки и каналы после отдельных quality gates, инфраструктуру - по нагрузке, не по моде.

1.10 План повышения конкурсного результата

До 1 ноября максимум эффекта дадут реальные интервью/альтернативы, baseline/метрики, обоснованный охват, исправленный honest end-to-end и питч/роли. Порядок нужен по доказательствам: сначала уточнить job/покупателя, затем строить score, иначе можно идеально реализовать ненужную функцию.

Быстро: маркировка mock, SIM=0, datetime/subject/amount/id, offline assets, удаление ложных promises из demo narrative. Сложнее: данные, experiment power, quality labels, bank owner и реальная интеграция. Для двух человек сократить до RU+одного языка и case, product ведёт discovery, developer - reliability; для 3-5 можно выделить аналитику/QA. Команда и её доступное время пока неизвестны. [Roadmap \(раздел 8\)](#) содержит сроки, трудоёмкость, зависимости и критерии, а не неограниченный список новых функций.

1.11 Главные причины возможного проигрыша red team

«Вы не доказали проблему именно этой аудитории»

Защита действием и доказательством. Исследовать эпизоды и альтернативы, отказаться от недоказанного сегментного тезиса, если интервью его не поддержат

«У нас уже есть антифрод»

Защита действием и доказательством. Сравнивать коммуникационный слой при одинаковом сигнале; предъявить uplift, а не спорить сложностью правил

«Ваша поддержка и заморозка - выдумка»

Защита действием и доказательством. Пометка mock уже сейчас; затем устойчивый sandbox case; никаких заявлений о банковском действии без подтверждения

«Предупреждение пришло после ухода денег»

Защита действием и доказательством. Признать ограничение replay; исследовать подходящий момент предупреждения, отдельно проектировать pre-transfer contract

«Алгоритм обвинит семью за общий сбор»

Защита действием и доказательством. Независимые legitimate negatives, FPR/CI и мягкий текст, не автономная блокировка

«Демо сломается на первом своём запросе»

Защита действием и доказательством. Исправить date/TZ/SIM/subject, smoke failure-path, локальные ассеты и видео backup

«Экономика завышена»

Защита действием и доказательством. Считать incremental bank-attributable loss, учитывать support/FPR/OPEX/K; предъявить отрицательный сценарий

«Семь языков - только семь строк»

Защита действием и доказательством. Выбрать один приоритетный язык и проверить весь job с носителями, время/понимание; не выдавать словарь за локализацию

«Система небезопасна для клиента»

Защита действием и доказательством. До gate только synthetic/shadow; trusted identity/data, least privilege, audit, legal templates

«Код легко скопировать, команда не подтверждена»

Защита действием и доказательством. Вложиться в методику/доказательства и конкретные роли/план; не придумывать moat и биографии

Одна проблема, способная уничтожить шансы: отсутствие доказанного дополнительного эффекта относительно существующей банковской защиты. Даже идеальная реализация небольшого rules engine не отвечает на вопрос, зачем банку отдельный продукт.

AI ради AI в текущем проекте нет; добавление LLM станет новым риском без доказательства потребности. Основные скрываемые потенциальные ограничения - токс действий, постфактум-анализ, непроверенные переводы и отсутствие quality/экономических данных; их нужно вынести в явный limitations slide.

Два уровня пересмотра выполнены: (1) технические выводы сверены с runtime и отделены от статических гипотез, в частности XSS не назван воспроизведённым exploit; (2) стратегические/денежные выводы проверены на копируемость, отсутствие данных, двойной учёт эффекта, выборку и честность демо. Вердикт не опирается на одну положительную атаку.

1.12 Финальный вердикт и ответы на обязательные вопросы

- 1. Что это?** Работающий синтетический демонстратор объяснимого риска, многоязычных алертов и обучения; не банковский antifraud/платёжный сервис.
- 2. Соответствие конкурсу?** Тематика сильная, доказательная и конкурсная готовность слабая; прогноз около 28/100 по предъявленным материалам.
- 3. Лучшее направление?** А, розничные клиенты: защита от мошенничества и помощь клиентам с языковым барьером. С - возможный вторичный эффект поддержки, но не основной трек.
- 4. Результат сегодня?** GREEN/RED-классификация и алерт на synthetic data. Для банка ожидается более безопасное поведение и меньше последствий/затрат, но эффект не измерен.

5. **Почему выбрать?** Сейчас нет доказанного превосходства. Выбрать могут за подтверждённое улучшение понимания/действия и реалистичный дешёвый пилот; эти доказательства ещё получить.
6. **Десять недостатков?** Нет Discovery; нет сегментного охвата; нет метрик/quality labels; нет реального УТП; mock поддержки/заморозки; небезопасный SIM-contract; дата/SIM/subject дефекты; неполная локализация/offline; нет валидированной экономики/пилота; нет подтверждённой команды/питча. Технические детали и тяжесть в T01-T22.
7. **Лучшие технологии?** Текущий FastAPI/Pydantic/Uvicorn, local HTML/CSS/JS, versioned rules/templates; PostgreSQL для case/audit и банковский gateway перед real data.
8. **Что заменить/убрать?** CDN runtime, поддерживаемый fallback deployment, небезопасный innerHTML, loose time/money schemas; из фокуса SIM/cashback. Не мигрировать весь продукт и не добавлять LLM.
9. **До первой сдачи?** Исправить date/TZ/SIM/subject, честные тексты и offline demo; получить интервью/охват/метрики; устойчивый case mock, source-backed материалы и роли.
10. **Пять задач с максимальным ростом?** Discovery; эксперимент/quality baseline; охват/покупатель; надёжный honest end-to-end; питч/пилот/команда. Прибавка не гарантирована и не складывается механически.
11. **Какие доказательства?** Эпизоды/цитаты, сравнение текущего warning, независимая разметка и CI, reachable сегмент, owner/contracts, реальные cost/effect inputs.
12. **Идеальное демо?** Synthetic trusted risk → понятный approved warning → действие клиента → подтверждённый sandbox case_id, плюс legitimate и failure scenario. Не обещать pre-transfer prevention до его реализации.
13. **Пилот?** Feasibility → read-only shadow → power-based UX A/B, с owner, data/security gates, support capacity, stop/rollback и экономикой.
14. **Ограничения безопасности/права?** ПДн/банковская тайна, доверенный субъект, on-prem isolation, AML/payment antifraud разграничение, reviewed legal texts; соответствие сейчас не установлено.
15. **Если мало времени?** Прекратить расширение scope, исправить падающие/ложные paths, честно пометить имитации и получить первые реальные свидетельства ценности. Лучше один проверенный язык и job, чем семь непроверенных обещаний.

1.13 ТОР 10 ДЕЙСТВИЙ ДЛЯ ПОВЫШЕНИЯ ШАНСОВ НА ПОБЕДУ

1. **Проверить job и сегмент интервью**, получить эпизоды и альтернативы, снять недоказанные тезисы (4-6 чел.-дней, рекрутирование может дольше).
2. **Устранить ложные claims о поддержке/заморозке/выплате**, сузить сценарий до warning→help (0.5-1 дня; высокий эффект доверия).
3. **Исправить date/TZ, SIM=0, субъект, дубликаты и нулевые события**, закрепить негативными проверками (2-4 дня).
4. **Измерить понимание и правильное действие на первом языке** относительно текущего текста, без выдачи разведочного n за доказанный uplift (3-4 дня + выборка).
5. **Получить независимую разметку и FPR/recall с CI**, включая законные похожие эпизоды (3-5 дней + data access).
6. **Подтвердить reachable охват и покупателя**, получить owner interview и источники параметров (2-3 дня + доступ к банку).
7. **Довести sandbox case до подтверждённого результата**, идемпотентность и safe failure (3-5 дней).

8. **Сделать offline/reproducible demo и безопасный DOM**, единый deployment, local assets, frozen dependencies (1-2 дня).
9. **Пересчитать экономику и пилот на фактических параметрах**, не скрывать убыточную базу и stop criteria (2-3 дня + данные).
10. **Собрать pitch/видео/командные роли и репетицию Q&A** до 01.11, приложить evidence/limitations (2-3 дня).

1.14 ЕСЛИ БЫ Я БЫЛ ТЕХЛИДОМ ЭТОГО ПРОЕКТА

Я сохранил бы небольшой FastAPI-монолит, правила и шаблоны. Зафиксировал бы один job: понятное предупреждение в момент риска и подтвержденная помощь банка. Сначала исправил бы очевидные runtime-дефекты и ложные success-состояния, затем сделал локальные assets и устойчивый case sandbox. Не вкладывался бы сейчас в реальные SIM-процессы, кешбэк, LLM, микросервисы и перенос frontend.

Параллельно product-участник должен получить интервью, baseline и доступный канал исследования, а аналитический review - независимые labels и экономические inputs. Без этих доказательств я не расширял бы функциональность. Если выяснится, что языковой барьер не влияет на действие, изменил бы продуктовую гипотезу по данным, а не пытался продать существующий интерфейс любой ценой. До реальных клиентов допустил бы только согласованный shadow и затем контролируемый UX-эксперимент. Цель - доказать дополнительную ценность и выполнимость пилота, сохранив честные границы текущего MVP.

2 Оценка по критериям жюри

Экспертный прогноз, не оценка организатора. Дата 08.10.2026. Шкала из текста кейса пользователя: 78 баллов спринт №1 + 22 онлайн-питч. Отдельная актуальная публикация организаторов не проверялась; будущие критерии второго спринта неизвестны. Новые отчёты содержат рекомендации и не превращают гипотезы в доказанные результаты.

2.1 Три сценария

Официальный критерий	Максимум	Строгий	Обычный	Благосклонный	После доработок, условно
Проблема, гипотеза, Discovery/JTBD, доказательства	20	3	5	7	13-16
Ценность и УТП	16	5	7	9	11-13
Аудитория, рынок, охват	14	0	1	2	8-10
Продуктовые метрики	12	0	1	2	7-9
Зрелость: движение к MVP	16	8	10	12	12-14
Спринт №1	78	16	24	32	51-62
Питч и сторителлинг	10	0	1	2	6-8
Интерес ВТБ и путь к пилоту	6	2	3	4	4-5
Команда и готовность	6	0	0	0	3-5
Онлайн-питч	22	2	4	6	13-18
Итого	100	18	28	38	64-80

Центр прогноза - **около 28/100**, разумный диапазон **18-38** при оценке только представленного репозитория. Уверенность суммарной оценки низкая: не представлены команда, реальное выступление и исследования вне Git. Ноль означает отсутствие предъявленных доказательств, а не неспособность команды. Баллы нельзя использовать как вероятность победы. Потенциал 64-80 требует выполненных исследований, метрик и демонстрации, а не только новых документов.

2.2 Основания и конкретные действия

Проблема / средняя

Что подтверждено. README называет риск вербовки; S01/S02 подтверждают общий контекст

Почему снижение. Нет интервью и доказательства именно нерезидентского сегмента; слова «главная мишень» не доказаны

Что нужно для высокой оценки / действие. 12-15 разведочных интервью, 4-6 банковских, анонимизированные цитаты и карта JTBD; проверить альтернативы и частоту проблемы

Ценность / средняя

Что подтверждено. E05/E06: объяснимый алерт на семи языках

Почему снижение. Нет преимуществ относительно существующего предупреждения; risk score не измеряет предотвращение

Что нужно для высокой оценки / действие. Сравнить понятность/правильное действие на банковском baseline и целевом языке; убрать ложные promises; сформулировать узкое УТП

Аудитория / высокая в пределах репо

Что подтверждено. Сегмент назван

Почему снижение. Нет численности, каналов, доступного охвата и покупателя

Что нужно для высокой оценки / действие. Формула охвата с данными банка, карта каналов, интервью владельца процесса; не заменять размер рынка всем миграционным потоком

Метрики / высокая

Что подтверждено. Есть score и технические metrics

Почему снижение. Это не показатели продуктового эффекта, нет baseline/разметки/событий

Что нужно для высокой оценки / действие. Определить North Star, FPR/recall и guardrails; получить baseline и реальные замеры на независимой выборке

Зрелость / высокая

Что подтверждено. E02-E07/E26: работающие API, UI, тесты

Почему снижение. T01-T18: имитации, 500, SIM=0, смещение клиентов; два демонстрационных CSV

Что нужно для высокой оценки / действие. Исправить основные дефекты; добавить воспроизводимый offline demo и mock case API; показать отрицательные сценарии

Питч / низкая

Что подтверждено. README предлагает 3-минутную историю

Почему снижение. Готовые слайды/видео и исполнение не представлены

Что нужно для высокой оценки / действие. 90-секундное честное демо, 10-12 тезисных слайдов, ответы с источниками; репетиция с таймером

Интерес/пилот / средняя

Что подтверждено. Направление A: antifraud и нерезиденты

Почему снижение. Нет подтверждённого владельца, доступа к данным и интеграционного контракта

Что нужно для высокой оценки / действие. Предложить read-only shadow этап и A/B клиентского предупреждения; согласовать песочницу и stop criteria

Команда / низкая

Что подтверждено. Факт наличия кода

Почему снижение. Авторство кода не доказывает состав 2-5 и готовность развивать

Что нужно для высокой оценки / действие. Именованные роли, часы до дедлайна, зона ответственности, доказуемые компетенции; никаких вымышленных биографий

2.3 Три причины непрохождения отбора

1. Исследования, аудитория и метрики дают до 46 баллов, но фактических артефактов по ним почти нет.

2. Разрыв между показанным предупреждением и обещанным банковским действием: кнопка «поддержка» не создаёт обращение и не ограничивает переводы.
3. У ВТБ уже есть антифрод, обучение и защитные клиентские сервисы; дополнительная ценность этого слоя не доказана.

2.4 Три действительных сильных стороны

1. Тематическое попадание сразу в antifraud и помощь нерезидентам; не требуется притягивать чужой трек.
2. Небольшой работающий прототип легко показать и проверить; объяснимые правила без внешнего inference.
3. Контекстный многоязычный алерт уже реализован технически. Его преимущество по пониманию и действию пока гипотеза.

2.5 Пять задач с наибольшим ожидаемым влиянием

Discovery с проверяемыми артефактами → baseline и эксперимент → обоснованный охват → честный устойчивый end-to-end → пилот/питч и роли. Ожидаемый эффект не суммируется как гарантированные прибавки: одни доказательства влияют на несколько критериев и оценки зависят от жюри.

3 Продукт аудитория рынок и метрики

08.10.2026. **Рекомендуемая позиция:** клиентский слой понятного предупреждения и безопасного обращения поверх банковского антифрода. Не замена антифрод-платформы ВТБ. [Источники и ограничения \(раздел 10\)](#).

3.1 Суть продукта

Одно предложение: «Анти-Дроп» показывает клиенту понятное предупреждение о признаках транзитной схемы на выбранном языке; в целевом MVP ведёт к подтверждённому обращению в банк.

30 секунд: «Человек получает предложение принять и переслать деньги, не понимая последствий. Наш прототип распознаёт несколько прозрачных признаков риска и показывает предупреждение на одном из семи языков. Предлагаем ВТБ проверить, повышает ли понятный контекстный текст долю безопасных действий относительно обычного предупреждения. Детектор и алерты уже работают на синтетических данных; банковское обращение пока имитируется. Следующий шаг - валидировать понимание, точность и путь к реальной поддержке в песочнице».

Продуктовое описание, 150-200 слов:

«Анти-Дроп» - прототип сервиса финансовой безопасности для клиентов, которым сложно понять предупреждения банка на русском языке. Главный сценарий возникает, когда человеку предлагают принять деньги на свою карту и перевести их дальше за вознаграждение. Продукт должен помочь распознать риск и обратиться в банк до дальнейшего участия в подозрительных операциях. Сейчас приложение получает набор транзакций, применяет прозрачные эвристики и показывает риск с объяснением. При высоком результате доступно предупреждение на одном из семи языков. Также реализованы учебные истории, квиз и демонстрационная форма смены номера. Последние функции не подключены к выплатам, SMS или банковскому учёту.

Предлагаемый покупатель и владелец эффекта - банк, заинтересованный в уменьшении последствий мошенничества и улучшении клиентской коммуникации. Рабочая гипотеза заключается в том, что контекстное предупреждение на понятном языке повышает вероятность безопасного действия по сравнению с обычным уведомлением. Она пока не проверена исследованиями. Для пилота продукт следует встроить поверх существующего антифрода: получать доверенный сигнал риска, показывать согласованный текст и создавать подтверждённое обращение. Первый этап должен использовать синтетические либо разрешённые обезличенные данные и не управлять платежами. Ценность будет определяться качеством предупреждения, долей правильных действий, нагрузкой на поддержку и дополнительным предотвращённым ущербом, а не количеством функций или наличием искусственного интеллекта».

Пользователь: не «любой иностранец», а клиент с языковым/контекстным барьером в конкретном переводном сценарии. Нерезидентство и гражданство не тождественны языку или риску; не использовать происхождение как риск-фактор. Плательщик: потенциально банк, гипотеза B2B-лицензии/модуля либо внутреннего продукта; готовность платить **НЕ ПОДТВЕРЖДЕНА**.

Измеримый результат сегодня: классификация синтетического эпизода и выдача объяснения. Снижение потерь, обращения и правильные действия ещё не измерены. Узкая точка входа: рискованный транзит → понятное предупреждение → подтверждённый кейс поддержки. SIM, cashback и широкая финансовая адаптация размывают эту точку.

3.2 JTBD и проблемные интервью

JTBD: «Когда мне предлагают принять и переслать чужие деньги и я не уверен в безопасности предложения, я хочу понять риск на понятном языке и быстро получить помощь банка, чтобы сохранить доступ к своим деньгам и не участвовать в опасной схеме».

- Функциональная задача: отличить подозрительную просьбу, прекратить дальнейшие действия, обратиться официально.
- Эмоциональная: уменьшить страх и неопределённость, не чувствовать обвинение.
- Социальная: отказаться от давления знакомого, сохранив лицо; гипотеза, требует интервью.
- Контекст: перевод/подработка/ошибочное поступление; trigger - сообщение вербовщика или предупреждение банка.
- Альтернативы: звонок/чат банка, знакомый переводчик, памятка, поиск, отказ от операции.
- Барьеры: недоверие к предупреждению, страх блокировки, непонимание текста, плохая связь, отсутствие цифровых навыков, привычка просить знакомых, чрезмерные тревоги.

Вопросы без подталкивания:

1. Расскажите о последнем переводе, в котором вы сомневались. Что произошло по шагам?
2. Кто участвовал и откуда пришла просьба?
3. Что вы сделали сначала, а что потом?
4. Как вы решали, можно ли доверять просьбе?
5. Какой текст или предупреждение вы видели? Что из него поняли?
6. На каком языке вы обычно читаете банковские сообщения и почему?
7. Когда вы в последний раз обращались в банк? Что помогло или помешало?
8. У кого ещё спрашивали совета? Что получилось?
9. Что было самым трудным в этой ситуации? Каковы последствия?
10. Были ли предупреждения, которые вы проигнорировали? Что повлияло на решение?
11. Как сейчас поступаете, если деньги пришли неожиданно?
12. Какие способы помощи уже пробовали и почему продолжаете или перестали пользоваться?

Не собирать номера карт, реквизиты, OTP и реальные выписки. Разведочные 12-15 интервью с вариацией языка/опыта и 4-6 банковских интервью - целевой качественный набор, не статистически репрезентативная оценка распространённости. Рекрутирование через согласованные партнёрские/образовательные каналы, добровольность и минимизация данных.

H1 Языковой барьер мешает безопасному действию

Метод и выборка. 12-15 интервью; сравнение разнообразных эпизодов до насыщения

Подтверждение / опровержение, заранее предлагаемые. Подтверждение: ≥5 независимых конкретных эпизодов барьера с последствиями; опровержение сегментной гипотезы: барьер редко фигурирует и доминируют другие причины

Текущие доказательства. Только постановка README; НЕ ПОДТВЕРЖДЕНО

H2 Контекстный родной язык улучшает понимание

Метод и выборка. Рандомизированные сценарии standard RU vs целевой язык, blinded scoring; старт 40-60 участников для оценки дисперсии

Подтверждение / опровержение, заранее предлагаемые. Цель +15 п.п. правильного действия без роста ложного отказа; отсутствие эффекта/ухудшение опровергает. Для подтверждения нужна выборка по power, а не только 40 человек

Текущие доказательства. Технически 7 шаблонов; пользовательского эффекта нет

H3 Правила дают приемлемую точность

Метод и выборка. Размеченные эпизоды, отдельные пользователи/время; минимум 300 normal +100 risk для разведки

Подтверждение / опровержение, заранее предлагаемые. Предложение gate $FPR \leq 1\%$, $recall \geq 70\%$ с доверительными интервалами; провал на legitimate flows - пересмотр правил

Текущие доказательства. Два hand-crafted CSV и тесты, не accuracy

H4 Предупреждение помогает обратиться

Метод и выборка. 8-10 usability-сессий на язык с песочницей; затем A/B

Подтверждение / опровержение, заранее предлагаемые. $\geq 80\%$ выполняют правильный путь без подсказки, медиана $\leq 60c$; большинство теряется/боится - пересмотр UX

Текущие доказательства. Кнопка поддержки лишь имитация

H5 Банку нужен отдельный слой

Метод и выборка. 4-6 интервью antifraud/retail/support/compliance

Подтверждение / опровержение, заранее предлагаемые. Есть владелец, измеримый gap и согласованный следующий шаг; всё закрыто текущим продуктом/нет владельца - отказ от самостоятельной продажи

Текущие доказательства. Владелец НЕ ПОДТВЕРЖДЁН

H6 Экономика положительна

Метод и выборка. Реальные данные банка, sensitivity и shadow/A/B

Подтверждение / опровержение, заранее предлагаемые. Incremental benefit > recurring+integration на согласованном горизонте; FPR/support cost съедают эффект - уменьшение scope/остановка

Текущие доказательства. Только сценарная модель отчёта

Пороги H1/H4 - ориентиры качественного этапа, не доказательство популяционной эффективности. Для H2 при baseline 50% и эффекте 15 п.п. грубая оценка порядка 170 участников на arm при alpha .05/power .8; пересчитать под фактический baseline, кластеризацию и dropout. Для FPR: при 0 ошибках на 300 независимых normal верхняя 95% граница примерно 1% (rule of three), а не «точно 0%». При FPR около 1% нужна существенно большая normal-выборка для узкого интервала. Разметка не определяется самим скорингом.

3.3 Реальные альтернативы

Все страницы проверены 08.10.2026; дата публикации неизвестна, кроме BI.ZONE 25.09.2023. Это источники поставщиков, не сравнительные испытания.

BI.ZONE AntiFraud - прямой конкурент rules engine

Что подтверждено источником. Кросс-канальный анализ, офлайн-проверка правил

Что делает лучше / барьер перехода. Ширина процессов и готовая платформа; независимый benchmark/цена неизвестны

Возможный гар проекта. Не соревноваться платформой; проверить клиентскую коммуникацию поверх сигнала

ВТБ: безопасность - внутренние аналоги

Что подтверждено источником. Инструкции и защитные сервисы

Что делает лучше / барьер перехода. Уже в клиентском канале, доверие и путь к банку

Возможный гар проекта. Понятность конкретного предупреждения для языкового сегмента пока не исследована

ВТБ: Защита близких - косвенный

Что подтверждено источником. Контроль переводов/снятий

Что делает лучше / барьер перехода. Подтверждение доверенным человеком; требует другого участника

Возможный гар проекта. Сценарий самостоятельной помощи без такого человека, гипотеза

ВТБ: марафоны - косвенный

Что подтверждено источником. Обучение безопасности

Что делает лучше / барьер перехода. Готовый контент и охват банка

Возможный гар проекта. Контекстное предупреждение прямо в момент риска, гипотеза

Чат/звонок и ручной перевод

Что подтверждено источником. Альтернатива из сценария, эффективность не измерена

Что делает лучше / барьер перехода. Доверенный человек, сложные обстоятельства

Возможный гар проекта. Меньше времени до понятного действия, только после сравнения

Почему ВТБ не сделать самому? Технически сделать аналог этих правил и шаблонов вполне возможно, и репозиторий не создаёт сильного барьера копирования. Убедительный аргумент может дать только уже проверенная методика языковой коммуникации, качественная разметка/переводы, измеренный incremental uplift и низкая цена внедрения. Пока этого нет. УТП в форме проверяемой гипотезы: «согласованное контекстное предупреждение на понятном языке повышает долю правильных действий при том же банковском сигнале риска». Не заявлять «уникальный антифрод».

3.4 Аудитория и три сценария охвата

TAM: все клиенты банков РФ с релевантным языковым/контекстным барьером и доступом к цифровому каналу. Число неизвестно. SAM: такие клиенты в доступных банках/языках/каналах. SOM: реально подключённые и достижимые в горизонте пилота/года. Статистика миграции или общие потери от мошенничества не равны этим величинам. Источник S01 доказывает общую проблему, не численность сегмента.

Формула доступного охвата: $N = \text{eligible_clients} \times \text{digital_reach} \times \text{supported_language_share} \times \text{rollout_share}$. Все четыре параметра требует банк; не собирать гражданство без необходимости. Предпочтительный канал - уже доверенное банковское приложение, а не отдельная установка.

Сценарий, все числа гипотетические	Eligible	Reach	Language share	Rollout	N в год
Консервативный	100 000	50%	50%	40%	10 000

Сценарий, все числа гипотетические	Eligible	Reach	Language share	Rollout	N в год
Базовый	200 000	70%	60%	59.52%	≈50 000
Оптимистичный	500 000	80%	75%	50%	150 000

59.52% в базе - только механическая подгонка иллюстрации к 50 тыс., не оценка с такой точностью; использовать округлённый rollout≈60% и N≈50 тыс. Все числа из допущений аудитора, **не статистика ВТБ**. Pilot SOM - 200-500 добровольных участников для коммуникационного usability/feasibility этапа, не для доказательства сокращения редких потерь. Частота: событийная, по риску; DAU/удержание сами по себе не цель. Reach, alert rate, повторное понимание через 2-4 недели измерять отдельно.

3.5 Метрики

North Star: **добавочная доля подтверждённых безопасных действий в релевантных рискованных эпизодах относительно стандартного предупреждения**. Безопасное действие определяется до эксперимента (например, прекращение подозрительного продолжения + подтверждённое обращение); клик сам по себе не доказательство спасённых денег. Истинная метка эпизода подтверждается независимо, без кругового вывода по score.

Все baseline сейчас **неизвестны**. Targets - предложенные критерии обсуждения, не достижения.

NSM / primary

Определение / формула. $\text{safe_action_rate}(T) - \text{safe_action_rate}(C)$ в релевантных эпизодах

Источник. Confirmed case/outcome и экспериментальная группа

Baseline. Неизвестен

Target. +15 п.п. в сценарном тесте; полевой gate согласовать

Как измерять. Рандомизация, CI, ITT, analysis plan

Понимание

Определение / формула. верно объяснили риск и шаг / показанное предупреждение

Источник. Независимая rubric, переводчик

Baseline. Неизвестен

Target. ≥80%

Как измерять. Blinded scoring без подсказок

Завершение помощи

Определение / формула. подтверждённые case / попытки открыть помощь

Источник. case service + event log

Baseline. Неизвестен

Target. ≥95% технического completion

Как измерять. Сквозной event_id, ошибки отдельно

Время до действия

Определение / формула. median и p90 от view до confirmed safe action

Источник. Timestamped events

Baseline. Неизвестен

Target. median ≤ 60с в usability

Как измерять. Без включения времени ожидания внешней поддержки в UX latency

False positive rate

Определение / формула. $FP/(FP+TN)$ на независимых normal эпизодах

Источник. Adjudicated labels

Baseline. Неизвестен

Target. ≤ 1%, CI обязательно

Как измерять. Holdout и представительные legitimate сценарии

Recall / precision

Определение / формула. $TP/(TP+FN)$; $TP/(TP+FP)$

Источник. Разметка risk/normal

Baseline. Неизвестен

Target. Recall ≥ 70%; precision gate после prevalence

Как измерять. По эпизодам и сегментам, out-of-time

Guardrail отказа

Определение / формула. ложные отказы от законного действия / normal episodes

Источник. Контрольная группа + follow-up

Baseline. Неизвестен

Target. Не хуже контроля более чем на 2 п.п.

Как измерять. Отдельный safety endpoint

Нагрузка поддержки

Определение / формула. дополнительные контакты / 1000 показов, handling minutes

Источник. Агрегаты поддержки

Baseline. Неизвестен

Target. В пределах согласованной capacity и экономики

Как измерять. Не считать время «сэкономленным», если контактов стало больше

Принятие

Определение / формула. views/eligible delivered; language chosen/eligible; completion обучения

Источник. Минимальная analytics

Baseline. Неизвестен

Target. Feasibility ≥ 80% delivery; цель банка

Как измерять. Техническая доставка отдельно от comprehension

Экономика

Определение / формула. incremental avoided bank loss + support savings – incremental costs

Источник. Верифицированные исходы и финансы

Baseline. Неизвестен

Target. Положительная NPV/окупаемость ≤ 24 мес. как гипотеза

Как измерять. Контрольная группа и банковская доля эффекта

Безопасность

Определение / формула. cross-subject exposures, real data egress, unauthorised cases

Источник. Security tests/audit

Baseline. Не измерен

Target. 0 критических инцидентов

Как измерять. Negative tests + pilot monitoring

Надёжность

Определение / формула. error rate, p95 API latency при согласованном batch

Источник. Metrics сервиса

Baseline. Только local median E24

Target. error < 1%, p95 ≤ 200 ms как draft

Как измерять. Нагрузочный профиль и hardware обязательны

События: risk_evaluated, alert_delivered, alert_viewed, language_selected, help_started, case_confirmed, safe_action_confirmed, content_completed, quiz_submitted, request_failed. Поля: event_id, schema/rule/template_version, coarse time, experiment arm, reason codes, outcome code, псевдоним subject только если нужен linkage. Не записывать raw phone, device_id, counterparty, полный текст операции/ОТР. Псевдонимизация и retention согласуются с банком; small-cell разрезы подавлять.

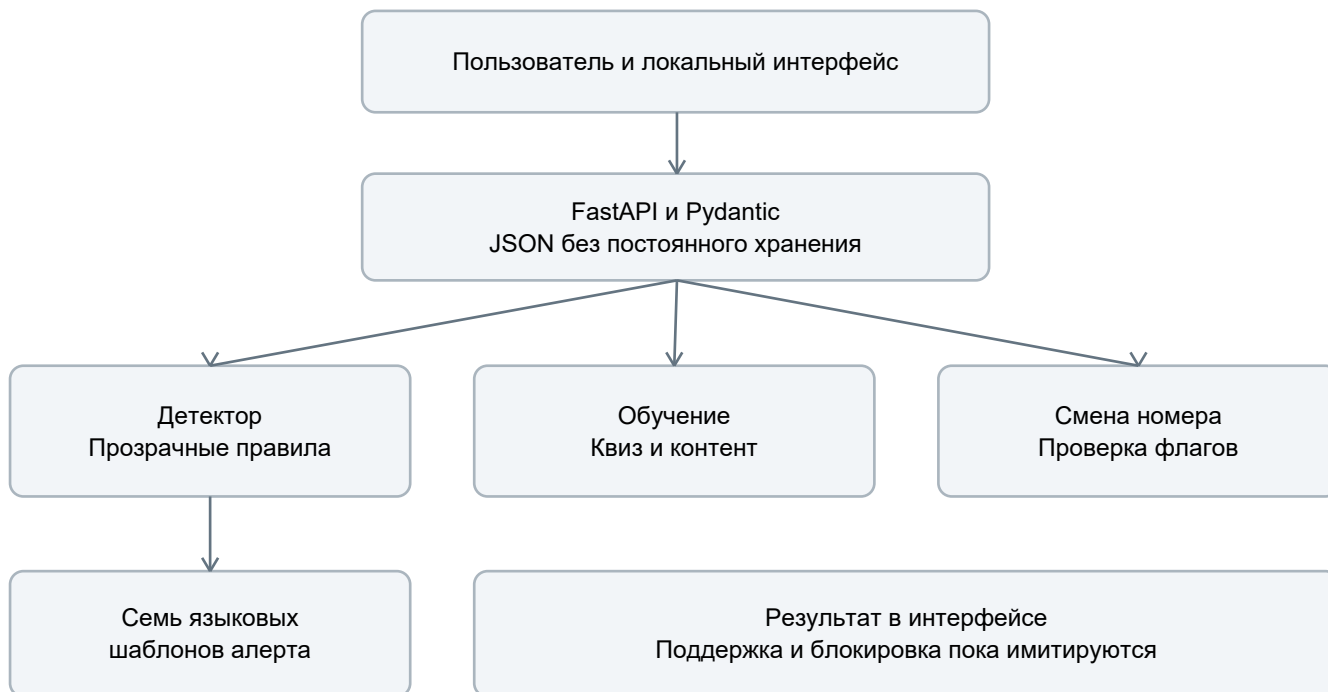
3.6 Эксперимент

Сначала 8-10 usability-сессий на первый язык и 40-60 сценарных участников для baseline/dispersions, без реальных денег. Затем power-based рандомизированное сравнение одинакового риска при standard и adapted warning, primary и guardrails фиксируются заранее. Не менять правила одновременно с языком - иначе эффект не атрибутируется. Полевая фаза только после security gate: shadow scoring, read-only, bank standard remains available; контроль получает текущую защиту, а не её отсутствие. Редкие реальные потери потребуют большего срока/выборки; 200 человек не докажут ROI. Собрать жалобы/ошибки и интервалы, не только среднюю долю кликов.

4 Технический аудит и реестр дефектов

08.10.2026. Основания и статусы: [реестр \(раздел 10\)](#), машинные результаты (машинное приложение), OSV (машинное приложение).

4.1 Действительная архитектура



Нет БД, очередей, аутентификации, миграций, банковских/телеком-интеграций, модели ИИ, CI/CD и Docker. Это не скрытые недоработки инфраструктуры: приложение действительно является stateless-демонстратором. Векторного поиска, RAG и inference нет. «Мониторинг» запускается загрузкой фиксированного сценария или ручным POST, не подпиской на банковские события.

Главный поток: выбор сценария → SCEN преобразуется в транзакции → POST analyze → сортировка, окна 60 минут/24 часа, суммирование правил → RED/YELLOW/GREEN → при RED языковой шаблон → DOM. Данные не сохраняются. Кнопка поддержки заканчивает поток локальным сообщением, а не банковским действием.

4.2 Инвентаризация

Backend

Реально есть. FastAPI, 6 API-маршрутов: 3 GET и 3 POST; static, docs

Ограничение. Всего GET API: health/langs/content = 3; POST: analyze/quiz/sim = 3. Не считать автоматически созданные docs банковской интеграцией.

Схемы

Реально есть. Pydantic v2, Literal типов, amount ≥ 0 , ≤ 5000 операций

Ограничение. ts - строка; user_id/id часто по умолчанию; нет запрета смешанных субъектов

Логика

Реально есть. Семь правил, ограниченный score 0-100

Ограничение. Нет калибровки, вероятностной интерпретации и проверки на отложенной выборке

Frontend

Реально есть. Один HTML, Tailwind CDN, vanilla JS

Ограничение. Нет сборки, типизации, обработки fetch-ошибок и устойчивого состояния

Данные

Реально есть. Два CSV + SCEN в JS + константы контента

Ограничение. Нет персистентности и событий аналитики

Резервный сервер

Реально есть. HTTPServer, встроенные HTML/CSS

Ограничение. Второй UI/API, другой контракт, меньше валидации, раскрывает правильные ответы

Качество

Реально есть. unittest, httpx TestClient, uv.lock

Ограничение. Нет конфигурации lint/typecheck, UI regression и CI; штатные тесты узкие

Локальный deploy

Реально есть. start-local.ps1, .venv, журналы .local

Ограничение. Скрипт из предыдущего задания; не банковский deployment и не авторестарт

4.3 Результаты запуска

14/14 tests PASS; pip check PASS; синтаксис 12 Python-файлов PASS. Живой API и Edge подтверждают норму GREEN/0, атаку RED/85. Семь алертов возвращаются по выбранному коду. Переводы не проверены носителями. Резервный сервер проверялся временно на случайном localhost-порту, закрыт после проверки.

Установлено: FastAPI 0.142.4, Pydantic 2.13.5, Uvicorn 0.54.0, Starlette 1.7.0, httpx 0.28.1. Это фактически установленный набор, не заявление о latest. OSV querybatch вернул 0 известных advisory для 22 установленных пакетов, исключая pip. uv.lock содержит более широкий набор из fastapi[standard]; не все его ветки проверены. Сборка frontend отсутствует по архитектуре; отдельные lint/typecheck не настроены и не заявляются пройденными. Чистая установка из lock на другом ПК не выполнялась.

4.4 Реестр дефектов и разрывов готовности

Трудозатраты - инженерные оценки в человеко-днях, включая узкие регрессионные проверки, без банковских согласований. **BLOCKER/CRITICAL для пилота не означает невозможность показать синтетическое локальное демо.**

T01 BLOCKER пилота, PARTIAL

Файл, причина и последствие. models.py:61-65, src/sim_security.py:26-49: клиент сам утверждает OTP; номер и лимиты не сохраняются

Воспроизведение. POST sim с обоими true → ok=true без SMS

Исправление / трудоёмкость / конкурс. Исключить из основного MVP; если сохранять для пилота - банковский IAM/OTP, серверный state machine, TTL, replay protection и enforcement. 5-10+ дней после контрактов. Подбивает доверие к защите

T02 HIGH, VERIFIED

Файл, причина и последствие. static/index.html:151-154: ложное подтверждение поддержки/заморозки

Воспроизведение. Нажать поддержку; только DOM меняется

Исправление / трудоёмкость / конкурс. Явная демо-пометка; затем sandbox case API с устойчивым case_id и статусом. 0.5 дня маркировка / 2-4 дня mock. Главный разрыв end-to-end

T03 HIGH, BROKEN

Файл, причина и последствие. models.py:13, src/detector.py:23-33: ts строка и необработанные exceptions

Воспроизведение. ts='bad' → 500; mixed timezone → 500

Исправление / трудоёмкость / конкурс. datetime schema, timezone policy, нормализация UTC и контролируемые 422; 1 день. Риск падения на вопросе жюри

T04 HIGH, BROKEN

Файл, причина и последствие. src/detector.py:110: 0 or 999

Воспроизведение. SIM=0, две входящие → false

Исправление / трудоёмкость / конкурс. Различать None/0, ge=0, параметризованный тест 0/1/2/3/None; 0.25 дня. Ошибка ключевого правила

T05 HIGH, BROKEN

Файл, причина и последствие. src/detector.py:30-50: user_id не участвует в области анализа

Воспроизведение. Пять входящих на пять клиентов + вывод у шестого → RED/70

Исправление / трудоёмкость / конкурс. Контракт одного subject_id с запретом смещения; банковский subject брать из доверенного контекста. 1 день. Иначе риск бессмысленных тревог

T06 HIGH пилота, VERIFIED

Файл, причина и последствие. src/detector.py:32-50: нет дедупликации id

Воспроизведение. Одинаковые id с повторными событиями принимаются

Исправление / трудоёмкость / конкурс. В API одного snapshot отклонять дубликаты; в event adapter уникальный source+event_id. 1-2 дня. Защита от искусственного роста риска

T07 MEDIUM, BROKEN

Файл, причина и последствие. models.py:15, src/detector.py:46-53: ноль допустим и участвует в числе мелких входящих

Воспроизведение. Пять входящих amount=0 → YELLOW/45

Исправление / трудоёмкость / конкурс. Исключить непроведённые/нулевые операции по контракту, amount>0 для переводов. 0.5 дня

T08 MEDIUM, BROKEN

Файл, причина и последствие. src/detector.py:33,43,81: now последняя операция; нет верхней границы

Воспроизведение. Будущая операция относительно явного now учитывается

Исправление / трудоёмкость / конкурс. Явный analysis_at, [start,now], режим исторического replay отдельно. 1 день

T09 HIGH пилота, PARTIAL

Файл, причина и последствие. src/detector.py:52-128: произвольные пороги, сумма коррелированных правил

Воспроизведение. Калибровочных данных нет

Исправление / трудоёмкость / конкурс. Набор легитимных/рисковых эпизодов, временной holdout, отчёт FPR/recall. 3-5 дней + получение данных. Не называть 85 вероятностью 85%

T10 HIGH, BROKEN

Файл, причина и последствие. app_stdlib.py:159-162: QUIZ целиком в HTML

Воспроизведение. GET / содержит correct

Исправление / трудоёмкость / конкурс. Убрать fallback из конкурсного пути или выдавать sanitized quiz; 0.5 дня. FastAPI ответ не раскрывает correct

T11 MEDIUM, BROKEN

Файл, причина и последствие. app_stdlib.py:167: кириллица в status reason не кодируется latin-1

Воспроизведение. GET /docs или /missing → разрыв соединения

Исправление / трудоёмкость / конкурс. ASCII reason, UTF-8 body; 0.25 дня. Не обещать одинаковый контракт двух серверов

T12 HIGH вне localhost, VERIFIED

Файл, причина и последствие. app_stdlib.py:170-175,203: неограниченный body/read, нет timeout policy, bind 0.0.0.0, однопоточный сервер

Воспроизведение. Статическое чтение; DoS не запускался

Исправление / трудоёмкость / конкурс. Не выставлять fallback в сеть; убрать из deployment. 0.5 дня

T13 MEDIUM, BROKEN

Файл, причина и последствие. src/sim_security.py:13-25: нормализация только для regex, сравнение raw strings

Воспроизведение. Один телефон с пробелами/дефисами принят новым

Исправление / трудоёмкость / конкурс. Каноническая форма перед сравнением/сохранением; 0.5 дня

T14 HIGH пилота, VERIFIED

Файл, причина и последствие. main.py:35-40,71-100: нет auth, ACL, rate limit; CORS *

Воспроизведение. Без Authorization все demo API работают; preflight *

Исправление / трудоёмкость / конкурс. Для демо только синтетика; для пилота gateway identity, RBAC/subject binding, TLS/mTLS, quotas. 3-5 дней + банк

T15 MEDIUM, PARTIAL

Файл, причина и последствие. src/detector.py:125, static/index.html:130-143: непроверенный текст в innerHTML

Воспроизведение. Подтверждён sink, исполнение JS не воспроизведено

Исправление / трудоёмкость / конкурс. textContent/DOM construction; reason codes + безопасные параметры. 0.5-1 день. Не преувеличивать как доказанный exploit

T16 MEDIUM, VERIFIED

Файл, причина и последствие. static/index.html:137-179: нет res.ok/catch/loading; ответы могут прийти в другом порядке

Воспроизведение. Инспекция; сетевые гонки не воспроизводились

Исправление / трудоёмкость / конкурс. Ошибки/повтор, disable button, request sequence/AbortController. 1 день

T17 MEDIUM, VERIFIED

Файл, причина и последствие. static/index.html:7: зависимость от внешнего исполняемого JS

Воспроизведение. URL CDN в HTML

Исправление / трудоёмкость / конкурс. Скомпилировать CSS локально; self-host Swagger либо закрыть docs. 0.5-1 день. Надёжное офлайн-демо

T18 MEDIUM, VERIFIED

Файл, причина и последствие. src/quiz.py:62-79: нет пользователя и учёта награды

Воспроизведение. Два запроса → два сообщения 100

Исправление / трудоёмкость / конкурс. Пометить награду условной, убрать реальное обещание; ledger/idempotency только при реальном reward adapter. 0.25 дня маркировка

T19 MEDIUM, VERIFIED

Файл, причина и последствие. models.py:15, src/detector.py:46-86: float для денег

Воспроизведение. Нет денежных проводок; арифметика классификатора

Исправление / трудоёмкость / конкурс. Для интеграции integer minor units или Decimal с валютой и округлением. 0.5-1 день; сейчас не дефект списания денег

T20 MEDIUM, VERIFIED

Файл, причина и последствие. requirements.txt:1-4, pyproject.toml:9-14: нижние границы, разные extras

Воспроизведение. pip-среда не равна всей uv.lock

Исправление / трудоёмкость / конкурс. Один frozen-путь установки, разделить dev/runtime, smoke в CI. 1 день

T21 MEDIUM, VERIFIED

Файл, причина и последствие. src/alerts.py:18-25, src/quiz.py:13-69, src/detector.py:56-107: категоричные обвинения/юридические исходы

Воспроизведение. Текст шаблонов

Исправление / трудоёмкость / конкурс. Нейтральный язык риска, согласованный юридический текст и перевод носителями. 1-2 дня + review

T22 LOW/MEDIUM, VERIFIED

Файл, причина и последствие. static/index.html:94-101: input телефонов без label, aria-live для результатов нет, арабский без dir

Воспроизведение. По коду; assistive tests не проводились

Исправление / трудоёмкость / конкурс. label/inputmode/tel, live region, keyboard focus, RTL, reduced motion. 1-2 дня

Нет дефекта «двойное списание»: проект вообще не списывает деньги. Нет конкурентных обновлений или транзакций БД, поскольку нет состояния. Именно поэтому promise «заморожено» нельзя считать выполненной финансовой операцией. При введении ticket/reward нужна идемпотентность; при платежном enforcement - отдельный доверенный банковский контур.

4.5 Качество и эксплуатация

Дублируется прежде всего UI и API-обвязка `app_stdlib.py`, а не само ядро. Сохранить один путь FastAPI. Сложность ядра примерно $O(n \log n)$ сортировка + несколько $O(n)$ проходов; повторный парсинг `ts` можно убрать после корректной валидации. Переписывать на Go ради 5000 операций не обосновано.

Объяснения «нетипично для вас» не опираются на персональную baseline. Алгоритм не проверяет порядок прихода/вывода денег, только суммы окна; вывод мог предшествовать поступлениям. `Device novelty` использует первые две операции как fallback-историю, не реестр доверенных устройств. Поля `counterparty/device_id` допускают пустые строки и неограниченную длину; данные о SIM и устройстве не должны приходить из недоверенного браузера в пилоте.

FastAPI sync handlers допустимы для короткого CPU-анализа; переход на async сам по себе CPU не ускорит. Нужны ограниченный размер HTTP-body на gateway, лимиты concurrency и deadline. Метрики `requests/latency/errors`, `version rules` и `request_id` отсутствуют. Uvicorn access-log не является аудитом банковского действия. В fallback `log_message` отключён, что дополнительно затрудняет диагностику.

Конфигурация сейчас в константах; для пилота отделить policy version/thresholds от runtime secrets, с контролем изменений. Проверенных секретов в отслеживаемых исходниках не выявлено при чтении; история Git и полноценный secret scanner не проверялись. `.local` не игнорируется, не коммитить рабочие журналы автоматически.

4.6 Минимальная стратегия проверки после исправлений

Контракт: invalid time, timezone normalization, mixed subject, duplicates, future, empty, 5000/5001, zero/negative/nonfinite amounts. Правила: границы 2/3/5 входящих, 0/1/2/3 дня SIM, 59/60/61 минут, порядок out-before-in. Alert: RED без small incoming должен давать подходящее объяснение, а не ложный текст о транзите. UI: ошибочный API, повторный click, смена сценария при задержке, RTL и offline assets. Ticket mock: повтор одного idempotency key даёт один case_id; timeout не превращается в «создано».

Нынешние тесты не измеряют эти свойства. `test_cashout_is_red` допускает и YELLOW: название сильнее проверки; `test_quiz_cashback` для плохих ответов проверяет конъюнкцию, а не независимо `passed=false` и `cashback=0`. Добавлять точные тесты по найденным рискам, без механического зеркалирования реализации.

5 Технологии и целевая архитектура

Сохранить Python/FastAPI и объяснимые правила. Крупная миграция сейчас отнимет время у проверки ценности. Дата 08.10.2026; фактические версии и ограничения проверки см. [реестр \(раздел 10\)](#). Оценки времени ниже - допущения для небольшой команды, не оферта.

5.1 Выбор компонентов

API

Сейчас. FastAPI/Pydantic/Uvicorn

Рекомендация и причина. Оставить; строгие schemas, error mapping, request_id, version rules. ASGI deployment описан в [официальной документации](#)

Цена / риск. 2-4 чел.-дня на hardening; низкий риск

Приоритет. P0

Деньги/время

Сейчас. float + строка ts

Рекомендация и причина. minor units+currency либо Decimal; datetime с явной TZ, UTC в обработке

Цена / риск. 1-2 дня и regression

Приоритет. P0

UI

Сейчас. vanilla JS в одном HTML

Рекомендация и причина. Пока оставить; безопасный DOM, error/loading, полноценный локализованный главный путь

Цена / риск. 2-4 дня; низкий риск

Приоритет. P0

Стили

Сейчас. Tailwind browser CDN

Рекомендация и причина. Локально собранный CSS, pinned tooling; [Play CDN](#) - инструмент разработки

Цена / риск. 0.5-1 день; меньше сетевых зависимостей

Приоритет. P0

Второй сервер

Сейчас. app_stdlib.py

Рекомендация и причина. Исключить из поддерживаемого пути деплоя; CLI оставить для диагностики

Цена / риск. 0.5 дня документация/границы; удаление только отдельным решением

Приоритет. P0

Хранение

Сейчас. Нет

Рекомендация и причина. PostgreSQL для case/state/audit после появления сохраняемого сценария. До этого не добавлять БД только ради галочки

Цена / риск. 2-4 дня + схемы/миграции; средний риск

Приоритет. P0 для case, P1 для расширения

Аутентификация

Сейчас. Нет

Рекомендация и причина. Банковский gateway/SSO и доверенный subject; для sandbox тестовый identity-provider с явно тестовыми учётками

Цена / риск. 3-5 дней после контракта; банк может потребовать больше

Приоритет. До реальных данных

Очереди

Сейчас. Нет

Рекомендация и причина. Не добавлять до требования доставки/скорости; case можно сохранять синхронно. Outbox при внешнем асинхронном side effect

Цена / риск. 2-4 дня только при необходимости

Приоритет. Пилот

CI

Сейчас. Нет

Рекомендация и причина. CI выбранного хостинга: frozen deps, unittest, Ruff, schema/contract smoke, dependency/SBOM review

Цена / риск. 1-2 дня

Приоритет. P0

Упаковка

Сейчас. Ручной локальный запуск

Рекомендация и причина. Docker Compose для воспроизводимой sandbox-сборки API/DB; Linux base из разрешённого registry. Не обещать поддержку банковского runtime до согласования

Цена / риск. 1-2 дня + offline test

Приоритет. P0/P1

Наблюдаемость

Сейчас. Access logs + health

Рекомендация и причина. request_id, error rate, latency, volume, rule_version; redacted JSON logs. Prometheus/Grafana при пилоте, OTel если банк уже использует

Цена / риск. 1 день минимум / 2-4 дня integration

Приоритет. P0/пилот

Edge проху

Сейчас. Нет

Рекомендация и причина. Nginx или банковский gateway для TLS/body/timeouts; не дублировать банковские функции без необходимости

Цена / риск. 1-2 дня; согласование отдельно

Приоритет. Пилот

AI

Сейчас. Нет

Рекомендация и причина. Не добавлять LLM/RAG. Оценивать правила на размеченных эпизодах; классическое ML позже при доказанном выигрыше

Цена / риск. Сэкономит время и эксплуатацию

Приоритет. KEEP NO AI

5.2 Альтернативы и стоимость выбора

React + TypeScript + Vite

Когда уместна. Несколько команд/сложные состояния, библиотека банка, много экранов

Решение сейчас. Вернуться после контракта банковского UI; перенос трёх экранов оценочно 4-7 дней + regression. Сейчас выигрыша для демонстрации не доказано

Vue + TypeScript

Когда уместна. Те же задачи, если команда уже владеет Vue

Решение сейчас. Аналогичный выбор по компетенциям; не мигрировать ради предпочтений аудитора

Next.js

Когда уместна. SSR/SEO, маршрутизация публичного сайта

Решение сейчас. Для банковского интерактивного экрана SEO не нужно; серверный слой усложнит deployment

Java / Spring Boot

Когда уместна. Банк требует JVM и располагает командой сопровождения

Решение сейчас. Python adapter оставить для пилота, согласовать контракт. Полный перенос/повторная валидация оценочно 10-20 дней, выгода сейчас отсутствует

Go

Когда уместна. Строгие latency/RSS и измеренный bottleneck

Решение сейчас. Не доказано. Цена переписывания/регрессии оценочно 8-15 дней

Node.js / NestJS

Когда уместна. Единая TS-команда с реальной компетенцией

Решение сейчас. Не уменьшает продуктовые пробелы; 7-12 дней на перенос без доказанного выигрыша

Redis

Когда уместна. Shared TTL/rate limiting/cache между репликами

Решение сейчас. Не использовать как основной аудит/ledger; добавить при реальной потребности и согласовать лицензию версии

ClickHouse

Когда уместна. Большой поток аналитики с профильными запросами

Решение сейчас. Для двух CSV не нужен; хранить минимум событий, экспортировать в банковскую аналитическую платформу

PostgreSQL + pgvector / Qdrant / OpenSearch

Когда уместна. Векторный retrieval / полнотекстовый поиск

Решение сейчас. Задачи retrieval нет: не добавлять

Celery/RabbitMQ

Когда уместна. Долгие jobs и подтверждённая потребность в retry/очереди

Решение сейчас. Возможно позже для расследования/локализации контента, не для короткого rules engine

Kafka

Когда уместна. Уже существующий банковский event backbone

Решение сейчас. Подключить адаптер к имеющемуся контуру; не разворачивать новый кластер для MVP

Kubernetes

Когда уместна. Банк предоставляет platform и стандартизированный путь

Решение сейчас. Не делать отдельную платформу силами команды 2-5 человек

Loki/OTel/Prometheus/Grafana

Когда уместна. Интеграция в эксплуатацию

Решение сейчас. Использовать существующие банковские средства; не настраивать всё одновременно

Неустановленные альтернативы не проходили benchmark и лицензирование; цифры времени - порядок стоимости, сильно зависящий от команды. Подробное сравнение версии каждой отвергнутой технологии нецелесообразно, поскольку она не входит в целевой score.

5.3 Лицензии версии ресурсы

FastAPI и Pydantic - MIT; Uvicorn - BSD; PostgreSQL - PostgreSQL License. Проверено 08.10.2026 по первичным источникам. Нужен SBOM точного поставляемого релиза: upstream branch не заменяет инвентаризацию wheel/transitive dependencies. У самого проекта LICENSE отсутствует; права использования/доработки подтвердить владельцем.

Python 3.12 уже установлен, .python-version указывает 3.12; ruproject допускает >=3.10. Не обновлять стек до latest ради аудита. Зафиксировать одну проверенную среду и обновлять целенаправленно после advisory/regression. On-prem доступность Python и PostgreSQL технически возможна, но включение в реестр российского ПО и разрешение банка не заявляются. Российский PostgreSQL-совместимый дистрибутив выбирать из утверждённого банком списка с проверкой лицензии/поддержки.

Начальная ресурсная гипотеза sandbox: 2 vCPU/4 GB RAM для API, отдельная небольшая DB при добавлении case. Это **не измеренный sizing**. Замер 37.9 ms на 5000 синтетических операций в TestClient не подтверждает QPS, p95, память и SLA. Перед пилотом замерить реальные распределения batch size, concurrency, ingress rate, длительность запросов и рост истории. GPU не требуется.

5.4 Три архитектуры

Быстрый надёжный MVP: один FastAPI, локальный HTML/CSS/JS, детерминированные fixtures, валидированные snapshots одного клиента, один case mock с устойчивым состоянием и явной пометкой sandbox; sqlite допустим только для автономной демо-фиксации с ограничением одного процесса, предпочтительнее сразу согласованный PostgreSQL если команда его знает. Без SIM, денежных наград и автономного ограничения переводов. Демо запускается без сети и проходит негативные сценарии.

Банковский пилот: gateway/SSO → FastAPI → rules/templates; доверенный read-only event adapter, PostgreSQL для минимального case/audit и event dedup, bank case adapter с отдельной identity, локальные ассеты, закрытый runtime egress, redacted observability. Shadow scoring сначала, затем согласованный UX-эксперимент; решение о платеже остаётся у банка. DB schema version, backup и restore проверяются.

Масштабируемая цель: API/UX и обработчики событий отделяются только при измеренном давлении на latency/throughput; partition by subject, оконное состояние, event dedup, versioned rules, outbox/retry для действий, деградация к банковскому стандартному предупреждению. Реплики/HA по согласованным RTO/RPO; данные и analytics интегрируются с платформой банка. Kafka/Kubernetes используют существующий сервис, а не строятся заново.

5.5 AI evaluation без добавления лишнего ИИ

LLM не нужен для определения риска по нынешним правилам; генерация юридических предупреждений увеличит вариативность и review burden. Предварительно переведённые/согласованные шаблоны надёжнее. RAG не решает нынешнюю задачу. Возможное классическое ML: ranking риска после появления достаточной разметки и baseline; внедрять только при out-of-time улучшении recall при фиксированном FPR.

Фреймворк качества применим уже к правилам: независимые эпизоды norm/attack/ambiguous, семейные сборы, зарплата+наличные, повтор событий, разные зоны, границы суммы/окна, SIM=0, новый device, пустые/неполные данные. Эталон - решение профильного аналитика с adjudication спорных случаев; два CSV не являются validation set. Train/tune/test разделить по пользователю и времени; считать episode-level precision/recall/FPR, PR curve и alert rate, p95 latency и CPU cost/request. Никаких промптов/галлюцинаций в текущем коде нет; применимы input validation и безопасность шаблонов. При неопределённости - «нужна проверка», не обвинение/блокировка. Рекомендуемые критерии обсуждения: FPR ≤1% на независимо размеченных нормальных эпизодах, recall ≥70% на известных типах риска, p95 ≤200 ms для согласованного batch/железа; значения являются гипотезами для gate, не измеренными достижениями. На небольшой тестовой выборке указывать интервалы неопределённости.

6 Безопасность и регулирование

Дата 08.10.2026. Оценка фактического прототипа, не юридическое заключение и не аттестация.

Локальные доказательства (раздел 10), дефекты (раздел 4).

6.1 Данные и границы доверия

Фактический POST analyze: id, user_id, время, тип, сумма, counterparty, device_id, давность смены SIM, выбранный язык. POST sim: старый/новый телефон, два boolean. Ответы квиза - индексы. В репозитории синтетические данные, паспортов/карт/биометрии нет. В реальном контуре телефоны и идентификаторы, связанные с человеком, могут быть ПДн; история операций и сведения о клиенте требуют оценки режима банковской тайны. Псевдонимизация сама по себе не означает обезличивание.

Доверенные банковские факты о клиенте, SIM, устройстве и операции в пилоте должны поступать от сервера банка. Сейчас их может произвольно задать любой API-клиент. API не отделяет клиента от аналитика или администратора. В памяти процесса данные живут в запросе; собственной БД, backup и политики удаления нет. Это не доказательство полного отсутствия копий: browser memory, reverse proxy и системные журналы тоже надо учитывать.

Browser → API

Сейчас. HTTP localhost; нет identity и TLS

Требование до реальных данных. Банк подтверждает сессию, subject binding, gateway TLS, RBAC; запрет прямого клиентского изменения доверенных фактов

API → ядро

Сейчас. Принятый JSON; неполная валидация

Требование до реальных данных. Строгие schemas, лимиты строк/тела, единое время, один субъект, дедупликация

Ядро → UI

Сейчас. Строки reasons в innerHTML

Требование до реальных данных. reason codes и textContent, CSP после удаления inline handlers

UI → CDN

Сейчас. Внешний исполняемый Tailwind JS

Требование до реальных данных. Локальные ассеты, deny egress; self-host или закрыть docs

API → действия банка

Сейчас. Отсутствует

Требование до реальных данных. Вначале только shadow/read-only; отдельный адаптер и подтверждённые статусы, least privilege

Оператор → данные/политики

Сейчас. Ролей нет

Требование до реальных данных. SSO/RBAC, аудит изменения правил, четырёхглазый review значимых policy

CDN получает сетевой запрос браузера, включая сетевые метаданные. Прямой отправки транзакций на CDN в коде нет; внешнее исполняемое JS имеет возможности в контексте страницы. Нельзя говорить

«данные уже утекли» без доказательств, но это ненужная граница риска для on-prem.

6.2 Threat model

Активы: корректный риск, ПДн/операции, доверие к предупреждению, будущие case_id и аудит.

Противники: недоверенный API-клиент, мошенник с контролем клиента, злоумышленник в сети, скомпрометированная зависимость, ошибающийся оператор. Не предполагается доступ к production банка.

Подмена субъекта/сигналов

Вектор / подтверждение. client user_id/SIM/device; E12/E21

Последствие. Некорректный риск и чужие сведения при будущей интеграции

Контроль / этап. Server identity + trusted event adapter; пилот

Подделка OTP

Вектор / подтверждение. otp_ok_* в JSON, T01

Последствие. При подключении к реальной смене - захват доступа

Контроль / этап. Не подключать этот endpoint к IAM; банковская проверка challenge, TTL, attempts, replay, recovery; пилот

Ложное ощущение защиты

Вектор / подтверждение. contactSupport только DOM, E09

Последствие. Человек считает деньги защищёнными

Контроль / этап. Уже для демо явно «имитация»; серверный case и подтверждённый статус позже

Отказ в обслуживании

Вектор / подтверждение. 500 на date, строки без length, body/read fallback

Последствие. Демо падает или сервис перегружен

Контроль / этап. Контролируемые 4xx, quotas, gateway body/timeouts; MVP/пилот

Неправильное срабатывание

Вектор / подтверждение. смешение клиентов, повтор событий, ноль, future

Последствие. Ложные обвинения/пропуск риска

Контроль / этап. T03-T09, валидация и независимый quality gate; MVP

HTML-инъекция

Вектор / подтверждение. reasons → innerHTML; E27 PARTIAL

Последствие. Потенциально изменение DOM/исполнение при небезопасном источнике

Контроль / этап. textContent; CSP и dependency review; MVP. Exploit не доказан

Supply chain/CDN

Вектор / подтверждение. внешний JS; unconstrained pip path

Последствие. Изменение поведения, нарушение изоляции

Контроль / этап. Локальная сборка, frozen deps, SBOM, registry mirror, подпись артефактов; MVP/пилот

Утечка через журнал

Вектор / подтверждение. нет политики, user_id/phone могут появиться при расширении logs

Последствие. Неограниченное распространение идентификаторов

Контроль / этап. allowlist полей логов, redaction, TTL и ACL; пилот

Повтор действия

Вектор / подтверждение. будущий case/reward без idempotency

Последствие. Повтор обращений/наград

Контроль / этап. unique key и атомарная запись состояния; до подключения действия

Ошибочная блокировка

Вектор / подтверждение. эвристический риск принимают за юридический факт

Последствие. Ограничение законного клиента

Контроль / этап. Не осуществлять автономные блокировки в MVP; bank policy + human review; пилот

CORS * не заменяет аутентификацию и сам по себе не является полным обходом авторизации. Сейчас auth вообще отсутствует; CSRF для cookie-session оценивается после выбора этой схемы. Закрытие /docs уменьшает экспозицию, но не защищает неавторизованный API.

6.3 Применимость требований

Официальные источники S01/S02 описывают антифрод и информирование. Полные актуальные редакции законов и нормативных актов не сверены; точная применимость определяется назначением компонента и банком. Не выводить правовую квалификацию из score.

Уже для конкурсного MVP

Что требуется. Только синтетика; отсутствие ложных утверждений о блокировке/ОТР/выплате; безопасная обработка JSON и текстов; локальные assets; описание обработки данных и рисков; согласование публичного юридического текста

Для пилота с ПДн

Что требуется. Уточнить роли оператора/обработчика по 152-ФЗ, цели/основания/минимизацию, локализацию при применимости, сроки, доступы, удаление/архив, incident response; договорные и технические меры

AML / 115-ФЗ

Что требуется. При использовании результата банком для AML - согласовать правила и процесс с комплаенс. Демонстратор не выполняет банковские обязанности AML и не подтверждает основания блокировки

Переводы / 161-ФЗ

Что требуется. При подключении к потоку переводов - согласовать антифрод, режим информирования и решения об операциях с банком; информирование, AML и payment antifraud не смешивать

Информационная безопасность банка

Что требуется. Банк определяет применимые акты Банка России, стандарты и криптографические требования, модель угроз, класс системы, logging и доступы. Упоминание 683-П в S02 не доказывает актуальность/достаточность полного перечня для этого пилота

Банковская тайна

Что требуется. Юристы банка определяют состав, основания передачи и режим доступа к операциям и данным клиента

Не относится сейчас

Что требуется. PCI-сертификация карточного процессинга, лицензирование платёжного оператора, требования к собственному inference/биометрии: соответствующих функций нет. При изменении score пересмотреть

Нельзя утверждать, что передача карты всегда автоматически является соучастием, или что любая RED-ситуация обязательно приводит к конкретному сроку лишения свободы. [src/alerts.py](#) и [src/quiz.py](#) требуют юридического и языкового review. Безопасный текст: «Операции похожи на рискованную схему. Не пересылайте деньги по просьбе незнакомцев. Свяжитесь с банком через официальный канал». Конкретные основания и последствия сообщает банк по обстоятельствам.

6.4 Рекомендуемый on prem



Все frontend/docs-ресурсы локальны; runtime egress запрещён по allowlist. Образы и зависимости поставляются через разрешённый registry; отсутствие сети проверяется отдельно. Secrets - в банковском secret store/защищённой конфигурации, не Git; сервисная identity с минимальными правами. Шифрование внутри/на диске и выбранные средства определяет ИБ банка; произвольное «AES/TLS» не является доказательством соблюдения российских требований. DB backup с ACL, сроками и тестом восстановления; audit append-only по согласованному процессу. Тест восстановления и offline deploy сейчас **НЕ ПОДТВЕРЖДЕНЫ**.

6.5 Входной security gate пилота

Владелец данных и процесса назначен; data flow согласован; security schemes и RBAC протестированы; нет открытых критических дефектов; SBOM/лицензии проверены; уязвимости обработаны; логи не содержат raw телефонов/операций; egress-test и restore-test пройдены; ошибки и таймауты возвращают безопасный статус; регуляторные/правовые тексты одобрены. Это будущие критерии, не уже выполненная проверка. Отсутствие реальных данных позволяет локальное демо сейчас, но не снимает эти условия для пилота.

7 Бизнес модель и финансовые расчёты

08.10.2026. Все денежные параметры ниже - допущения аудитора для проверки жизнеспособности. Ни один сценарий не является доказанной прибылью или бюджетом ВТБ. Фактических затрат команды и банковского эффекта нет. Цены инфраструктуры и ставки не являются рыночными котировками.

7.1 Покупатель и эффект

Вариант 1: внутренний модуль банка, эффект измеряется предотвращёнными **дополнительными** потерями банка и экономией поддержки. Вариант 2: B2B-лицензия + интеграция, но готовность платить, цена и procurement неизвестны. Подписка с клиента не рекомендуется до исследования: дополнительный барьер для защитного сценария. Revenue uplift от удержания пока принять равным нулю, чтобы не удвоить недоказанные выгоды.

Не складывать полную сумму всех остановленных переводов, общий ущерб клиентам и компенсации банка как независимые выгоды. L_{bank} - только та доля невозвратного экономического ущерба, которая приходится на банк и действительно меняется благодаря продукту. Снижение ущерба клиентам показывать отдельно как customer benefit.

7.2 Формулы и единицы

Горизонт - 12 месяцев устойчивого использования после запуска. N - уникальные охваченные клиенты/год. q - число релевантных подтверждённых рискованных эпизодов на клиента/год; в примере <1 , не «доля всех переводов». Δ - дополнительная доля предотвращённых эпизодов относительно текущей защиты. L - средний устранимый ущерб банка, Р/эпизод .

$\text{FraudBenefit} = N \times q \times \Delta \times L \text{ (Р/год)}$.

$\text{SupportBenefit} = N \times \text{contacts_per_client_year} \times \text{minutes_saved_per_contact} \times \text{cost_per_minute} \text{ (Р/год)}$, только для текущих обращений и без повторного учёта нового потока тревог.

$\text{FalseAlertCost} = N \times \text{false_alerts_per_client_year} \times \text{call_share} \times \text{handling_cost} \text{ (Р/год)}$. Это частота лишних уведомлений, **не FPR классификатора**; несколько уведомлений одному клиенту нужно учитывать отдельно.

$\text{AnnualMargin} = \text{FraudBenefit} + \text{SupportBenefit} + \text{RevenueUplift} - \text{OPEX} - \text{FalseAlertCost} - \text{Rewards}$.

$\text{Year1Net} = \text{AnnualMargin} - K$, где K - MVP + пилот + первоначальная интеграция без дублей. $\text{Year1ROI} = \text{Year1Net} / (K + \text{OPEX} + \text{FalseAlertCost} + \text{Rewards})$; знаменатель - все учтённые расходы первого года.

$\text{SimplePaybackMonths} = 12K / \text{AnnualMargin}$ только при $\text{AnnualMargin} > 0$, условно равномерный поток, без дисконтирования. Это не NPV/IRR.

7.3 Параметры источники и неопределённость

Параметр	Консервативный	Базовый	Оптимистичный	Источник / что получить
N, клиентов/год	10 000	50 000	150 000	Допущение; формула охвата в PRODUCT_AND_MARKET, нужны данные банка
q, risk episodes/client/year	0.005	0.010	0.015	Допущение; независимая разметка/история банка
Δ, incremental prevention	5%	10%	15%	Допущение; контрольный эксперимент, не recall детектора
L_bank, ₽/эпизод	15 000	20 000	25 000	Допущение; финансы банка, возмещения/возвраты/ответственность
contacts/client/year	0.10	0.10	0.10	Допущение; support aggregates
minutes_saved/contact	2	3	4	Допущение; time-and-motion до/после
cost/minute, ₽	20	25	30	Допущение; полная стоимость персонала, не тариф клиента
false alerts/client/year	0.04	0.03	0.02	Допущение; telemetry и adjudication
call_share after false alert	10%	10%	10%	Допущение; support linkage
handling_cost, ₽/контакт	300	300	300	Допущение; бухгалтерия поддержки
K, ₽	1 200 000	1 800 000	3 000 000	Иллюстративный бюджет, score зависит от банка
OPEX, ₽/год	1 200 000	1 800 000	3 000 000	Допущение: hosting+maintenance+review+support, детализация базы ниже
RevenueUplift	0	0	0	Не доказано, не включать в pitch как доход
Inference	0	0	0	В текущем продукте нет AI; CPU включён в infra
Rewards	0	0	0	Рекомендуется убрать cashback из фокуса; его чувствительность ниже

Числа N/q/Δ/L не выведены из статистики ЦБ. В частности, средний ущерб по всем мошенническим операциям не подставляется как L_bank для нерезидентского сегмента.

7.4 Пример базовой сметы

Статья	Расчёт	Р	Примечание
Создание MVP с исследованием/QA	500 ч × 1500 Р/ч	750 000	Это полная экономическая стоимость, не утверждение о зарплатах команды
Пилот: запуск, измерение, review	300 ч × 1500 Р/ч	450 000	Дополнительный труд, не повтор интеграции
Первоначальная интеграция	300 ч × 2000 Р/ч	600 000	Адаптеры/ИБ/контракты, не реальные расценки банка
К	Сумма	1 800 000	1100 человеко-часов полного пути, не только код до 1 ноября
Инфраструктура год	20 000 Р/мес × 12	240 000	Сценарная резервируемая сумма, не закупочная котировка
Сопровождение год	65 ч/мес × 1500 × 12	1 170 000	Обновления, инциденты, исправления
Контент/переводы/quality review год	Условный бюджет	240 000	Проверить стоимость носителей и юристов
Базовая поддержка эксплуатации год	Условный бюджет	150 000	Только сопровождение модуля; handling ложных тревог отдельно
ОРЕХ	Сумма	1 800 000	Без стоимости существующей банковской платформы, только incremental

При повторном использовании команды банка К может быть ниже; при сложной ИБ и procurement - выше. Не сокращать интеграционные затраты до нуля без оценки владельца.

7.5 Расчёт сценариев

Показатель, Р если не указано другое	Консервативный	Базовый	Оптимистичный
Дополнительно предотвращённых эпизодов, ожидание/год	2.5	50	337.5
FraudBenefit	37 500	1 000 000	8 437 500
SupportBenefit	40 000	375 000	1 800 000
Gross annual benefit	77 500	1 375 000	10 237 500
FalseAlertCost	12 000	45 000	90 000
OPEX	1 200 000	1 800 000	3 000 000
AnnualMargin	-1 134 500	-470 000	7 147 500
K	1 200 000	1 800 000	3 000 000
Year1Net	-2 334 500	-2 270 000	4 147 500
Year1ROI	≈-97%	≈-62%	≈68%
Простая окупаемость после запуска	Нет при этих параметрах	Нет при этих параметрах	≈5 месяцев

Дробные эпизоды - математическое ожидание, не реальные события. Оптимистичные 5 месяцев исключают время разработки, гап-ур и дисконтирование; не использовать как обещание. Консервативный и базовый варианты убыточны. Именно поэтому доказательства эффекта и достаточного охвата важнее новых экранов.

7.6 Чувствительность и break even

В базе годовой эффект на клиента: $0.01 \times 0.10 \times 20000 + 0.10 \times 3 \times 25 - 0.03 \times 0.10 \times 300 = 26.6$ Р/клиент/год до фиксированного OPEX. Текущий ежегодный net/client с OPEX при N=50 тыс.: -9.4 Р. K/N=36 Р первоначально.

При неизменном OPEX и остальных параметрах:

- Ежегодный break-even $N \approx 1\,800\,000 / 26.6 \approx \mathbf{68\,тыс.}$ клиентов.
- Окупаемость K за 24 месяца: нужно $\text{AnnualMargin} \geq K/2$; $N \geq (1.8 \text{ млн} + 0.9 \text{ млн}) / 26.6 \approx \mathbf{102\,тыс.}$
- При N=50 тыс. каждый дополнительный 1 п.п. Δ даёт $50000 \times 0.01 \times 0.01 \times 20000 = 100\,000$ Р/год.
- Ежегодный break-even $\Delta \approx 14.7\%$, вместо базовых 10%; для возврата K за 24 месяца $\Delta \approx 23.7\%$.
- При $\Delta=0$ остаётся 375 тыс. экономии поддержки против 1.845 млн annual cost: ценность не держится на одном обучении.
- Каждая сэкономленная минута/контакт в базе даёт 125 тыс. Р/год, если контакты и штатные расходы действительно сокращаются, а не просто перераспределяются.
- Cashback 100 Р при 20% участников добавляет 1 млн Р/год расходов в базе и ухудшает AnnualMargin до -1.47 млн. Повторные награды без защиты ухудшат ещё сильнее; нынешний API платежей не выполняет.

Break-even предполагает неизменные расходы при росте N; проверить ступенчатое расширение поддержки, инфраструктуры и языкового контента. Для финала добавить ежемесячные cash flows и discount rate, согласованные банком, если требуется NPV; не выбирать ставку произвольно.

7.7 Объяснение жюри за минуту

«Считаем только дополнительный эффект поверх текущей защиты. В иллюстративной базе 50 тысяч охваченных клиентов, один релевантный эпизод на сто клиентов в год и 10% добавочного предотвращения дают миллион рублей банковского эффекта. Поддержка добавляет 375 тысяч, эксплуатация и лишние тревоги стоят 1.845 миллиона - база пока убыточна. Проверяем, можем ли повысить эффективность, снизить стоимость интеграции или получить больший подтверждённый охват. Эти параметры не результаты пилота, а условия, которые пилот должен подтвердить или опровергнуть».

До защиты запросить: eligible/reach, независимую частоту risk episodes, bank-attributable loss, baseline текущей защиты, Δ с CI, поддержку до/после, фактическую смету интеграции/эксплуатации и допустимый срок окупаемости. Без этих данных финансовая модель полезна как проверка гипотез, но не доказательство ROI.

8 MVP дорожная карта и банковский пилот

Дата **08.10.2026**. По кейсу: сдачи 01.11, 29.11, 08.12, финал 11.12. Все дедлайны ещё впереди. Текущий код не изменялся в аудите. Трудоемкость - человеко-дни по 6 продуктивных часов, календарь зависит от доступности участников и банка.

8.1 Один целевой сквозной сценарий

Пользователь с выбранным языком получает просьбу переслать поступившие деньги. В sandbox поступает доверенный синтетический эпизод одного клиента. Система валидирует данные, вычисляет версионный риск, показывает согласованный понятный текст и предлагает официальный путь помощи. Пользователь подтверждает обращение; сервер sandbox сохраняет кейс и возвращает устойчивый ID. Финал: клиент понимает дальнейшее безопасное действие, case подтверждён, событие включено в измерение. Доказанный эффект сейчас - выдача алерта; понимание/прекращение рискованного действия должны измеряться. Нельзя показать реальную блокировку, пока нет банковского enforcement.

Важное ограничение текущего алгоритма: пять небольших входящих днём без свежей SIM и без вывода дают 45/YELLOW, алерт появляется только при RED≥50. Нынешнее RED-демо включает уже совершенный вывод. Нельзя называть его предотвращением первого перевода. Для pre-transfer сценария нужен явно проектируемый draft event/сигнал банка и отдельная валидация; не выдавать будущую функцию за текущую.

8.2 Приоритеты score

P0 конкурс

Функции. Один клиент/эпизод; корректные дата/SIM/amount/id; безопасный DOM; нейтральный согласованный первый язык + RU; offline assets; honest demo; case mock с подтверждённым state; метрики и исследование; reproducible run/tests

P1 если хватает времени

Функции. Второй приоритетный язык с носителями, отдельный экран оператора sandbox, расширение legitimate fixtures, простой CI/container, доступность/RTL для реально выбранного языка

P2 после доказательства

Функции. Bank OTP/recovery, изменение номера и enforcement; trained ML по размеченным данным; event scale/HA; новые каналы

REMOVE из главного питча

Функции. Cashback как доказанное начисление, автономная «заморозка», обещание поддержки за 2 минуты, отдельная SIM-фича, заявления «85% вероятность» и «лучше банковского антифрода»

REMOVE - рекомендация о фокусе, не выполненное удаление файлов. Полностью рабочий SMS-flow не является обязательным для выбранного конкурса, если он не заявлен в MVP.

8.3 Acceptance criteria и тесты

1. Один запуск на чистой согласованной среде; locked dependencies; демо без публичной сети. README-команда и поставляемый artifact совпадают.
2. Invalid/mixed-timezone/payload возвращают документированный 4xx; не 500. Mixed subject и duplicate IDs отклоняются или разделяются по явному контракту. SIM 0/1/2 корректны; будущие и нулевые операции не создают риск без правила.

3. Score/level/reason codes детерминированы с rule_version; score не выдаётся как вероятность. Исторический replay явно обозначен.
4. Норма, атака, legitimate high-activity, borderline и недоступный API показаны заранее; UI не оставляет ложный success и устаревший ответ после переключения.
5. Предупреждение говорит о риске, а не приговоре; первый целевой язык проверен носителем и юридическим review. Все действия главного пути локализованы.
6. Case mock сохраняет состояние: repeated idempotency key возвращает тот же case_id; ошибка/таймаут даёт unknown/failed и безопасный repeat. Банковская блокировка не симулируется как факт.
7. Нельзя читать/изменять кейс другого sandbox subject. Logs минимальны; реальные телефоны/операции не используются.
8. Primary metric и guardrails определены до эксперимента; baseline либо измерен, либо явно неизвестен. Два сценария не выданы за accuracy dataset.

Минимальные проверки: contract/negative из TECHNICAL_AUDIT; перезапуск с чтением сохранённого case; replay idempotency; unauthorized/cross-subject; UI error/slow request/offline; контроль approved template/version и отсутствие ответов квиса в публичном content. Синтетика должна включать добросовестные сборы, зарплату/наличные, ночных работников, повторы и границы окна, без имитации этнического risk scoring.

8.4 Проектируемые контракты интеграций не реализованы

RiskSnapshotV1: subject_ref из trusted context; analysis_at ISO UTC; event_id/source, occurred_at, amount_minor, currency, direction/type, counterparty_ref, trusted device/SIM flags; schema_version.

Ограничения: один subject, уникальные source+event_id, bounded size и допустимые часы.

RiskDecisionV1: evaluation_id, analysis_at, rule_version, level, score, reason_codes, template_id, status (ok/insufficient_data), без raw идентификаторов в тексте.

POST /sandbox/cases: evaluation_id, selected_language, contact_reason, Idempotency-Key; identity серверная. Ответ: case_id, status=created, created_at, next_step; HTTP 201 для нового, повтор → тот же ресурс. 4xx/5xx/timeout различаются; без выдуманной гарантии срока поддержки. GET case/{id} проверяет subject/роль. Mock интерфейса банка выдаёт только тестовые статусы; sandbox adapter никогда не сообщает payment_blocked без внешнего подтверждения. Эти имена контрактов - предложение отчёта, не существующие маршруты.

Демо без API банка: заранее описанный event source, sandbox case DB, искусственные роли, fixtures, видимый badge «синтетика/песочница». Записать offline видео как backup после исправлений; текущего видео в репозитории нет.

8.5 Дорожная карта

Срок / задача	Приоритет / почему	Труд оёмк ость	Зависимости	Результат / критерий готовности
8-11 окт: фокус и честная маркировка имитаций	P0, доверие и scope	0.5-1 д	Product + developer	Один primary scenario; ни один текст не утверждает неподтверждённую блокировку/начисление
9-15 окт: исправить T03-T08/T13/T15-T17	P0, стабильность/безопасность демо	4-6 д	Developer	Контрактные негативные тесты и offline run проходят
9-20 окт: Discovery и JTBD	P0, наибольший конкурсный gap	4-6 д	Доступ к респондентам, языковой помощник	Реальные записи с согласованием, карта проблем/альтернатив, подтверждения или отказ от сегментной гипотезы
12-20 окт: target language и usability	P0, измеримая ценность	3-4 д	Discovery, носитель, legal review	8-10 наблюдений на первый язык, scoring rubric, отчёт ошибок
15-23 окт: case sandbox	P0, end-to-end	3-5 д	Выбранный scope/state/identity	Один подтверждённый case, повтор безопасен, перезапуск не теряет состояние
18-26 окт: разметка и baseline	P0, метрики/качество	3-5 д + данные	Аналитик, antifraud reviewer	Независимый holdout, prevalence/CI и legitimate negative cases; если нет данных - ограничения явно указаны
20-28 окт: охват, эксперимент, экономика	P0, evidence	2-4 д	Интервью банка/агрегаты	Источники каждого параметра, гипотезы отделены, негативный сценарий включён
26-31 окт: pitch/demo/команда/артефакты	P0, сдача 1 ноября	2-3 д	Все предыдущие	Слайды/видео/code links/аналитика, репетиция 90с и failure path, роли 2-5 подтверждены
2-15 ноя: согласования и доработка	P1, подготовка без обещания официального спринта	3-6 д	Owner/ИБ/банк	Контракты, data access plan, перечень применимых требований; это внутреннее окно команды
16-29 ноя: hardening, финмодель, privacy	P0 спринта 2	6-10 д + review	Security/data gate	Sandbox интеграция, auth/audit, offline packaging, обновлённая модель с доступными данными
3-8 дек: пилотный пакет и final pitch	P0 спринта 3	3-5 д	Метрики, owner, ограничения	Согласуемый pilot protocol, criteria, scaling, финальные материалы до 8 декабря

Срок / задача	Приоритет / почему	Труд оёмк ость	Зависимости	Результат / критерий готовности
9-11 дек: репетиция/резерв	P0 финала	1-2 д	Стабильный релиз	Видео backup, frozen demo, Q&A; никаких крупных миграций

Оценки пересекаются по людям и требуют планирования, их нельзя сложить в календарь одного разработчика. До 1 ноября доступно около 3 недель; для двух участников полный список может не поместиться. **Сокращать scope:** оставить RU+один целевой язык, API+предупреждение+case, исключить SIM и reward, не мигрировать frontend. Продуктовый участник ведёт интервью/артефакты, инженер - исправления/case; QA выполняют взаимно. Если 3-5 человек, отдельно выделить исследование/аналитику и вторую инженерную/QA роль; ИБ/юриста/носителя привлекать на конкретные review. Наличие этих компетенций ещё не подтверждено.

8.6 Предложение пилота ВТБ

Потенциальная функция: клиентская antifraud-безопасность совместно с розничным digital и поддержкой. Предполагаемый process owner - руководитель клиентского antifraud/цифровых предупреждений; конкретных сотрудников и согласия ВТБ нет.

1. **Feasibility:** 200-500 добровольных участников из согласованного сегмента, первый язык, 2-4 недели, сценарное понимание и доставка; без доказательства реального fraud ROI.
2. **Shadow:** разрешённая историческая/псевдонимизированная выборка и read-only поток, 4-6 недель как плановая гипотеза. Сравнить с текущим сигналом и обработкой банка, не менять платежи.
3. **UX A/B:** только после gate; одинаковая текущая защита в обеих группах, новый слой текста/помощи в treatment. Размер определяется power и event rate; может быть существенно больше feasibility, срок зависит от частоты событий.

Вход: владелец, данные/законные основания, reviewed templates, access controls, data contract, instrumented baseline, power plan, support capacity, security gate. Успех: положительный primary uplift с CI, guardrails в пределах noninferiority margin, допустимые false alerts/support cost и экономика на согласованном масштабе. Draft thresholds из PRODUCT_AND_MARKET обсуждаются с банком, не являются обещанием.

Остановка: любая подтверждённая cross-subject утечка/несанкционированное действие - немедленно; превышение согласованных ошибок/нагрузки, жалобы/вред от формулировок - приостановка и review; недостаточная мощность/нет эффекта - не объявлять успех. Rollback: выключить feature flag адаптированного слоя, вернуть стандартное банковское предупреждение; не отключать защиту банка. Масштабирование по языкам/каналам после отдельно подтверждённой понятности и capacity; HA/event scale только по замерам.

Блокеры внешнего происхождения: доступ к респондентам, разметке/агрегатам, owner/ИБ и sandbox-контракту. Они блокируют доказательство пилота, но не синтетическое конкурсное демо. Если времени мало: сначала честность и главные runtime-дефекты, затем реальные интервью и измерение понимания, затем case. Не тратить неделю на Next.js, Kubernetes или LLM.

9 Демонстрация презентация и защита

Дата 08.10.2026. Это сценарий подготовки, а не созданная презентация или записанное видео. Слайды/видеофайл в текущем репозитории отсутствуют. Текст опирается на [проверки \(раздел 10\)](#); будущие функции помечены.

9.1 А Демо на 90 секунд что можно честно показать сейчас

0-15с

Экран / действие. Нормальный сценарий, GREEN/0

Реплика и граница утверждения. «Клиенту предлагают принять и переслать деньги. Мы проверяем гипотезу, что понятное предупреждение поможет отказаться от опасного продолжения. Это синтетическая песочница»

15-30с

Экран / действие. Выбрать язык, нажать «Симулировать атаку вербовщика»

Реплика и граница утверждения. «В сценарии пять небольших входящих, вывод и свежая SIM. Это фиксированные тестовые операции, не данные ВТБ»

30-50с

Экран / действие. RED/85, причины

Реплика и граница утверждения. «Сработали прозрачные правила. 85 - сумма баллов, не вероятность и не доказательство преступления. Предупреждение на выбранном языке»

50-65с

Экран / действие. Показать конкретный следующий шаг в алерте

Реплика и граница утверждения. «Текст объясняет риск и направляет в официальный канал помощи. Переводы ещё не проверены носителями»

65-78с

Экран / действие. Кнопка поддержки, только с явным пояснением

Реплика и граница утверждения. «В этой версии обращение имитируется в браузере. Реальный case и блокировка не созданы». Пока UI пишет обратное, произнести ограничение до клика; лучше исправить текст отдельной задачей

78-90с

Экран / действие. Слайд/устное завершение

Реплика и граница утверждения. «API и детектор работают; измеренный пока результат - выдача алерта. Следующая проверка: правильное действие и нагрузка поддержки относительно текущего предупреждения банка»

Не заявлять «предотвратили перевод»: в данных уже есть вывод, а pre-transfer gate отсутствует. Не показывать SIM/cashback как подтверждённую безопасность/выплату. Это ослабляет демонстрацию, но ложное обещание ещё опаснее.

Идеальное демо после R0: синтетический сигнал → локализованное предупреждение → подтверждённый sandbox case_id → запись результата; затем одним действием показать добросовестный похожий эпизод и отсутствие ложного успеха при API-ошибке. Новый case API сейчас НЕ РЕАЛИЗОВАН. При демонстрации до вывода нужно отдельно реализовать draft-event семантику, не

подменять завершённую операцию намерением.

Подготовка: frozen commit, local assets, smoke norm/attack/negative, размер окна заранее, 90с репетиция; offline видео как резерв после реализации. Не открывать live сторонние сервисы и реальные счета. На /docs показывать контракт только если это помогает ответить жюри; Swagger сам по себе не демонстрирует клиентскую ценность.

9.2 В Структура питча

1. Конкретная жизненная ситуация и job, без недоказанных слов «нерезиденты - главная мишень».
2. Доказательства: официальный общий контекст S01/S02; затем реальные интервью сегмента. Пока интервью нет - честно показать gap.
3. Пользователь и канал: языковой барьер в банковском приложении; число доступных клиентов неизвестно.
4. Решение в одном экране: понятный контекстный warning + официальный путь помощи.
5. 90-секундное демо с маркировкой синтетики и mock.
6. Альтернативы: существующая защита ВТБ и antifraud vendors; уникальность - гипотеза языкового результата, не сложность rules engine.
7. Метрики: baseline, uplift safe action, FPR/recall, false refusals/support load; никакой подмены score точностью.
8. Охват: формула $\text{eligible} \times \text{reach} \times \text{language} \times \text{rollout}$, фактические источники или пометка допущений.
9. Экономика: incremental bank benefit минус OPEX/ложные тревоги/integration; базовый пример сейчас отрицательный.
10. ВТБ/пилот: кто владеет процессом, read-only shadow, затем UX experiment, stop/rollback.
11. Безопасность: trusted data, on-prem/local assets, отсутствие автономных блокировок и внешнего ИИ.
12. Команда и запрос: реальные люди/роли/доступное время, помощь с исследованием/песочницей/разметкой. Имена и достижения не придумывать.

В коротком выступлении объединить пункты в 8-10 слайдов; один слайд - один проверяемый тезис. В приложении к слайдам: источники, контракты, отрицательные сценарии, финансовые допущения и реестр ограничений. Файлы .pptx/.pdf и публичное демо/видео - отдельные deliverables конкурсной сдачи; этот Markdown их не заменяет.

9.3 С Двадцать трудных вопросов

1. Почему ВТБ должен внедрить это?

Обоснованный ответ сегодня. Внедрение пока не обосновано. Предлагаем ограниченную проверку понятности warning в языковом сегменте поверх существующей защиты

Что получить до защиты. Подтверждённый owner, gap, baseline и uplift

2. Где подтверждение проблемы?

Обоснованный ответ сегодня. S01/S02 подтверждают общий риск и потребность информирования; нерезидентский приоритет ещё не доказан

Что получить до защиты. Интервью, эпизоды и агрегаты сегмента

3. Почему лучше того, что уже есть?

Обоснованный ответ сегодня. Превосходство не измерено; отличие текущего демо - шаблоны 7 языков и объяснения

Что получить до защиты. A/B с текущим текстом и одинаковым risk signal

4. Почему банк не делает это сам?

Обоснованный ответ сегодня. Может сделать. Копируемый код не является барьером. Ценность команды должна состоять в проверенной методике и быстром пилоте

Что получить до защиты. Исследования, approved translations, time-to-value и интеграционная стоимость

5. Где эффект в рублях?

Обоснованный ответ сегодня. Финмодель сценарная, база убыточна; мы не выдаём гипотезы за ROI

Что получить до защиты. Фактические $q/\Delta/L_{\text{bank/cost}}$ и sensitivity

6. Что означает 85?

Обоснованный ответ сегодня. Детерминированная сумма правил с cap=100; не 85% вероятности мошенничества

Что получить до защиты. Calibration/quality отчёт, version rules

7. Почему Python/FastAPI?

Обоснованный ответ сегодня. стек уже работает, простое ядро, быстрые схемы/контракты и локальный deployment; bottleneck не доказан

Что получить до защиты. Frozen build и нагрузка на согласованном профиле

8. Как интегрировать в банк?

Обоснованный ответ сегодня. Сейчас интеграций нет. Предлагается trusted snapshot/event adapter, затем case sandbox

Что получить до защиты. Bank schemas, identity и owner соглашение

9. Где данные и как защищены?

Обоснованный ответ сегодня. Сейчас синтетика и stateless-ответы, auth нет; реальные ПДн запрещены до gate

Что получить до защиты. Data map, RBAC, retention, legal basis, security review

10. Работает ли без интернета?

Обоснованный ответ сегодня. Ядро - да. FastAPI UI и docs сейчас зависят от CDN; полностью offline run не подтверждён

Что получить до защиты. Локальные assets и deny-egress test

11. Где ваш ИИ?

Обоснованный ответ сегодня. ИИ отсутствует и не нужен для текущей задачи; прозрачные правила и согласованные шаблоны

Что получить до защиты. Не нужно добавлять AI ради баллов; нужен quality baseline

12. Вы уже заморозили перевод?

Обоснованный ответ сегодня. Нет. Кнопка лишь меняет текст, а полномочий платежного контура нет

Что получить до защиты. Исправить утверждение; реальный enforcement отдельным score банка

13. Зачем форма смены SIM, если OTP можно подделать?

Обоснованный ответ сегодня. Это демонстрация, не защищённая смена; рекомендуем убрать из главного MVP

Что получить до защиты. Уточнить scope либо банковский OTP/recovery design

14. Кто получил кешбэк?

Обоснованный ответ сегодня. Никто: возвращается поле и сообщение, финансового исполнения нет

Что получить до защиты. Убрать обещание либо отдельный ledger/reward integration и budget

15. Какова точность детектора?

Обоснованный ответ сегодня. Не измерена. Два CSV и unit tests проверяют реализацию, не accuracy

Что получить до защиты. Независимая разметка, legitimate negatives, holdout, CI

16. Что с ложными тревогами на семейные сборы?

Обоснованный ответ сегодня. Нынешние признаки могут совпадать с законной активностью; риск real

Что получить до защиты. Negative fixtures, FPR по эпизодам, мягкие тексты/human review

17. Почему это достаточно зрелый MVP?

Обоснованный ответ сегодня. Технический демонстратор зрелее слайдов: живой UI/API, 14 тестов. End-to-end банковский результат ещё отсутствует

Что получить до защиты. Исправления P0, sandbox case и reproducible failure test

18. Законно ли объявлять человеку 6 лет?

Обоснованный ответ сегодня. Скоринг не устанавливает состав преступления. Такие категоричные тексты требуют замены/юридического review

Что получить до защиты. Approved legal wording + проверенные переводы

19. Как поймёте, что пилот успешен?

Обоснованный ответ сегодня. По заранее определённому uplift безопасного действия при guardrails и положительной экономике, не по кликам

Что получить до защиты. Primary/CI/power, control, stop criteria, signed protocol

20. Кто доведёт проект и что будет при отсутствии данных?

Обоснованный ответ сегодня. Состав и доступное время не представлены. Без банка можно проверить usability, но нельзя заявить fraud ROI

Что получить до защиты. Реальные роли 2-5, capacity plan; честно ограничить conclusions

9.4 Red team репетиция

Защита должна выдерживать показ негативного input, обсуждение legitimate false positive, отключение сети и вопрос о case. Самая опасная реплика: «Мы уже защитили деньги», когда система только показала HTML. Ответ должен содержать точную границу, подтверждённый результат и следующий эксперимент, а не скрывать mock техническим жаргоном. До фактических данных не использовать в презентации гипотетические финансовые результаты как достижения.

10 Доказательства источники и ограничения

Дата оценки: **8 октября 2026**, Europe/Moscow. Код: 565c72017c1be04e0734998b435d9db508940de9.
Отчёт относится к текущему локальному дереву; ранее добавленные CASE_REVIEW_RU.md и start-local.ps1 не являются исходными конкурсными материалами. Они не подтверждают исследования или интеграции.

10.1 Правила чтения

- **VERIFIED** - непосредственное чтение кода или выполненная проверка, в указанном объёме.
- **PARTIAL** - часть функции работает; результат целиком не подтверждён.
- **DOCUMENTED ONLY** - только обещание документации.
- **NOT VERIFIED / НЕ ПОДТВЕРЖДЕНО** - данных нет или проверка не проведена.
- **BROKEN** - безопасно воспроизведено нарушение ожидаемого контракта.

Отсутствие компонента означает отсутствие в исследованном дереве, а не доказательство отсутствия вне репозитория. Диапазоны ниже относятся к неизменённому коду, не к новым отчётам.

10.2 Локальные доказательства

E01

Вывод. FastAPI → Pydantic → четыре модуля stdlib; БД и интеграций нет

Статус. VERIFIED

Источник / проверка. main.py:6-100, models.py:10-75, все файлы src/; полный список git ls-files

E02

Вывод. 14 штатных тестов проходят

Статус. VERIFIED

Источник / проверка. .venv\Scripts\python.exe -B -m unittest discover -s tests -v: 14 tests, OK; повторный запуск в этом аудите

E03

Вывод. Синтаксис 12 Python-файлов корректен

Статус. VERIFIED

Источник / проверка. ast.parse для main/models/fallback/src/tests; verification-results.json:syntax

E04

Вывод. Живые /, health, docs, OpenAPI доступны

Статус. VERIFIED

Источник / проверка. HTTP 200 для четырёх маршрутов на 127.0.0.1:8000; verification-results.json:live

E05

Вывод. CSV normal GREEN/0, drop_attack RED/85

Статус. VERIFIED

Источник / проверка. Живой POST analyze, verification-results.json:live_scenarios; data/*.csv

E06

Вывод. Все семь кодов языка возвращают соответствующий алерт

Статус. VERIFIED

Источник / проверка. verification-results.json:all_languages; это не лингвистическая экспертиза переводов

E07

Вывод. Квиз проверяется сервером; FastAPI не выдаёт correct

Статус. VERIFIED

Источник / проверка. main.py:60-68,90-92; src/quiz.py:62-79; E02

E08

Вывод. SMS, кешбэк, смена номера, кулдаун не интегрированы

Статус. PARTIAL

Источник / проверка. models.py:61-65, src/sim_security.py:17-49, src/quiz.py:62-79; функции возвращают словари без сохранения и внешних вызовов

E09

Вывод. Кнопка поддержки имитирует обращение и блокировку

Статус. VERIFIED

Источник / проверка. static/index.html:151-154; просмотр Edge: сообщение об обращении и заморозке отображено; в функции только присваивание textContent

E10

Вывод. Невалидная дата и смещение timezone дают 500

Статус. BROKEN

Источник / проверка. models.py:13, src/detector.py:23-33; verification-results.json:invalid_date,mixed_timezones

E11

Вывод. SIM=0 не считается свежей

Статус. BROKEN

Источник / проверка. src/detector.py:110; verification-results.json:sim_today → false

E12

Вывод. Разные user_id агрегируются

Статус. BROKEN

Источник / проверка. src/detector.py:30-50; verification-results.json:mixed_users → RED/70 для шести разных клиентов

E13

Вывод. Повторяющиеся id не отклоняются

Статус. VERIFIED

Источник / проверка. verification-results.json:duplicate_ids → RED/70; бизнес-корректность требует контракта дедупликации

E14

Вывод. Нулевые входящие дают 45 баллов

Статус. BROKEN

Источник / проверка. models.py:15, src/detector.py:46-53; verification-results.json:zero_amounts → YELLOW/45

E15

Вывод. Будущая операция включается при явном now

Статус. BROKEN

Источник / проверка. src/detector.py:43,81; verification-results.json:future_included

E16

Вывод. Один номер в двух форматах принимается как изменение

Статус. BROKEN

Источник / проверка. src/sim_security.py:13-25; verification-results.json:same_phone_different_format → ok=true

E17

Вывод. Два прохождения квиза возвращают два cashback=100

Статус. VERIFIED

Источник / проверка. verification-results.json:repeat_quiz; это повтор сообщения, **не два платежа**

E18

Вывод. Fallback выдаёт correct в HTML

Статус. BROKEN

Источник / проверка. app_stdlib.py:159-162; verification-results.json:stdlib.quiz_answer_exposed

E19

Вывод. Fallback обрывает неизвестные GET вместо 404

Статус. BROKEN

Источник / проверка. app_stdlib.py:167: кириллица в HTTP reason; временный локальный HTTPServer → RemoteProtocolError / UnicodeEncodeError

E20

Вывод. CDN нужен для оформления FastAPI UI и Swagger

Статус. VERIFIED

Источник / проверка. static/index.html:7; HTML /docs содержит jsdelivr; fallback использует inline CSS

E21

Вывод. CORS '*' и отсутствие security schemes

Статус. VERIFIED

Источник / проверка. main.py:35-40, OpenAPI, отсутствие auth dependencies в маршрутах; preflight → *

E22

Вывод. Пакеты совместимы по declared requirements

Статус. VERIFIED

Источник / проверка. pip check → No broken requirements found; это не lock-install

E23

Вывод. OSV: 22 пакета, известных advisory не возвращено

Статус. VERIFIED

Источник / проверка. dependency-audit.json; запрос querybatch по установленным версиям, исключён pip. Не охватывает будущие advisory, JS CDN, ОС и все ветки uv.lock

E24

Вывод. Однопоточный локальный замер 5000 операций

Статус. VERIFIED

Источник / проверка. 10 последовательных TestClient-запросов: median 37.9 ms, max 40.2 ms. Не сетевой p95 и не нагрузочный тест

E25

Вывод. Доказательная база, финмодель, роли команды не представлены

Статус. NOT VERIFIED

Источник / проверка. В исходном дереве 21 tracked-файл; нет исследовательских артефактов, презентаций и описания команды

E26

Вывод. Демо в Edge: GREEN/0 → RED/85 и русское предупреждение

Статус. VERIFIED

Источник / проверка. CUA/Edge на localhost; кнопки «Атака», «Поддержка». Мобильные размеры, screen reader и полный E2E квиса/SIM не проверялись

E27

Вывод. Возможная HTML-инъекция через причины

Статус. PARTIAL

Источник / проверка. src/detector.py:125 включает device_id[:8], static/index.html:143 использует innerHTML. Проверка html_reason не воспроизвела выполнение JS; текущий UI генерирует фиксированные device_id. Не объявлять доказанным XSS

E28

Вывод. Пять входящих без вывода/свежей SIM не создают RED-алерт

Статус. VERIFIED

Источник и проверка. verification-results.json:pre_outgoing_five_incoming: YELLOW/45, alert=null; src/detector.py:52-53,128, main.py:75

10.2.1 Как повторить существенные проверки

Только синтетические данные; `TestClient(app, raise_server_exceptions=False)`.

```
client.post('/api/analyze', json={'transactions': [{'ts': 'bad', 'amount': 1}]})
```

Фактически 500, ожидается контролируемый 422.

```
client.post('/api/analyze', json={'transactions': [
```

```
{'ts': '2026-10-07T14:00:00+03:00', 'amount': 1},
```

```
{'ts': '2026-10-07 14:00:00', 'amount': 1}]})
```

Фактически 500; нужна единая политика времени.

Для `mixed_users`: пять входящих по 3000 от разных контрагентов, каждый на отдельный `user_id`, и исходящий 14000 у шестого `user_id`, одно время 14:00. Общий RED/70 показывает смешение субъектов. Для `SIM=0`: две входящие операции с разными контрагентами и `sim_changed_days_ago=0` дают `metrics.sim_changed_recently=false`.

10.3 Внешние источники

Все URL проверялись **08.10.2026**. Если дата публикации не показана явно, она неизвестна; дата индексации её не заменяет. Материалы поставщиков подтверждают заявленную функцию, но не её независимую эффективность. Ни один источник ниже не доказывает превосходство «Анти-Дропа» или высокий риск нерезидентов относительно остальных групп.

S01

Источник, дата публикации. [Банк России: обзор за 2025](#), дата страницы не установлена

Что подтверждает и предел. Общая проблема мошеннических операций значима; объём вырос на 6.4%, число на 31.2% относительно 2024. Это не статистика дропперства нерезидентов и не ТАМ продукта.

S02

Источник, дата публикации. [Банк России: методические рекомендации по информированию](#), дата в извлечённом PDF не читается

Что подтверждает и предел. Рекомендуются профилактическая информационная работа, в том числе о дропперстве. Не сертификат соответствия продукта.

S03

Источник, дата публикации. [Bl.ZONE AntiFraud, обновление](#), 25.09.2023

Что подтверждает и предел. Поставщик описывает кросс-канальный антифрод и офлайн-тестирование правил. Цена, текущее внедрение в ВТБ и сравнительная точность неизвестны.

S04

Источник, дата публикации. [ВТБ: финансовая безопасность](#), дата не указана

Что подтверждает и предел. У ВТБ уже есть инструкции и клиентские защитные сервисы; нишу надо доказывать поверх существующих средств.

S05

Источник, дата публикации. [ВТБ: Защита близких](#), дата не указана

Что подтверждает и предел. Клиентский контроль переводов и снятия наличных - реальная косвенная альтернатива; не аналог всех функций проекта.

S06

Источник, дата публикации. [ВТБ: образовательные марафоны](#), дата не указана

Что подтверждает и предел. Обучение финансовой безопасности уже существует. Эффект именно контекстного многоязычного обучения проекта не доказан.

S07

Источник, дата публикации. [Tailwind Play CDN](#), дата не указана

Что подтверждает и предел. Play CDN предназначен для разработки; для пилота нужен локально собранный CSS.

S08

Источник, дата публикации. [FastAPI: запуск сервера](#), дата не указана

Что подтверждает и предел. Uvicorn соответствует ASGI-архитектуре; выбор FastAPI оправдан. Не подтверждает банковскую пригодность конкретного приложения.

S09

Источник, дата публикации. [PostgreSQL: лицензия](#), дата не указана

Что подтверждает и предел. PostgreSQL License. Версию и поддержку выбранного дистрибутива согласовать для пилота.

S10

Источник, дата публикации. [FastAPI LICENSE](#), текущая ветка

Что подтверждает и предел. MIT; не замена проверке лицензий точного SBOM релиза.

S11

Источник, дата публикации. [Pydantic LICENSE](#), текущая ветка

Что подтверждает и предел. MIT; проверить точный пакет и транзитивные компоненты перед поставкой.

S12

Источник, дата публикации. [Uvicorn LICENSE](#), текущая ветка

Что подтверждает и предел. Лицензия BSD; исходный URL перенаправляется в Kludex/uvicorn.

S13

Источник, дата публикации. [OSV API](#), дата не указана

Что подтверждает и предел. Метод проверки известных уязвимостей версий пакетов; фактический ответ сохранён отдельно.

Попытка открыть <https://pd.rkn.gov.ru/operators/> через веб-инструмент не удалась. Актуальная полная редакция 152-ФЗ и полная применимость отраслевых актов в этом аудите **НЕ ПОДТВЕРЖДЕНЫ**. Раздел безопасности задаёт вопросы для банка, не заключение о соблюдении закона.

10.4 Пробелы и владельцы следующего доказательства

Пробел	Кто / что получить
Нерезиденты - приоритетный сегмент?	Product: интервью, языковая сегментация, агрегированные данные банка о сценариях
Эффект предупреждений и точность	Аналитик + antifraud: разметка, holdout, сравнение с текущими предупреждениями
Покупатель и интеграция	Product: интервью владельца клиентской безопасности, описание интерфейсов песочницы
Денежный эффект и расходы	Банк/финансы: фактическая доля потерь банка, стоимость обращений, интеграционные оценки
Право использования кода	Владелец репозитория: лицензия и цепочка прав; LICENSE отсутствует
Команда и ресурсы	Участники: состав 2-5, доступное время, роли, компетенции
On-prem в контуре банка	ИБ/эксплуатация: требования, согласованная сборка, проверка без egress

Проверки ограничены синтетическими данными. Production, реальные ПДн, платежи, разрушительные миграции и внешние SMS не использовались. Запрошенная установка зависимостей не повторялась: окружение уже установлено в предыдущем задании; lock-файлы не менялись.